CEH v13 AI (312-50) Study Guide - Module 09: Social Engineering

EC-Council CEH v13 AI (312-50) Exam-Focused Study Guide

Table of Contents

1. Module at a Glance
2. Big Picture Map
3. Topic-by-Topic Guide
    - 3.1 Learning Objectives [page 1, slide 2]
    - 3.2 What is Social Engineering? [page 1, slide 4]
    - 3.3 Types of Social Engineering [page 2, slide 5]
    - 3.4 Impersonation [page 2, slide 7]
    - 3.5 Eavesdropping [page 3, slide 9]
    - 3.6 Shoulder Surfing [page 3, slide 9]
    - 3.7 Dumpster Diving [page 3, slide 9]
    - 3.8 Reverse Social Engineering [page 3, slide 10]
    - 3.9 Piggybacking [page 3, slide 10]
    - 3.10 Tailgating [page 3, slide 10]
    - 3.11 Diversion Theft [page 3, slide 10]
    - 3.12 Honey Trap [page 4, slide 11]
    - 3.13 Baiting (and Bait and Switching) [page 4, slide 11; page 2, slide 5]
    - 3.14 Quid Pro Quo [page 4, slide 11]
    - 3.15 Elicitation [page 4, slide 11]
    - 3.16 Vishing [page 2, slide 5; no detail slide in the notes]
    - 3.17 Phishing [page 4, slide 13]
    - 3.18 Types of Phishing [page 5, slide 15]
        - Spear Phishing
        - Whaling
        - Pharming
        - Spimming
    - 3.19 Types of Phishing, continued [page 5, slide 16]
        - Clone Phishing
        - E-wallet Phishing
        - Tabnabbing and Reverse Tabnabbing
        - Consent Phishing
        - Search Engine Phishing
    - 3.20 Phishing Tools [page 6, slide 17]
        - The Social-Engineer Toolkit (SET)
        - ShellPhish
        - Other Phishing Tools (listed on the slide)
    - 3.21 Other Techniques for Computer-based Social Engineering [page 6, slide 19]
        - Pop-up Windows

Hoax Letters
Chain Letters
Instant Chat Messenger
Spam Email
Scareware
3.22 Deepfake Videos, Voice Cloning and AI-based Impersonation [page 2, slide 5; page 12, slide 36]
3.23 Perform Impersonation on Social Networking Sites [page 7, slide 22]
Angler Phishing
Catfishing Attack
3.24 Identity Theft [page 7, slide 23]
3.25 Publishing Malicious Apps and Repackaging Legitimate Apps [page 8, slide 25]
Publishing Malicious Apps
Repackaging Legitimate Apps
3.26 Fake Security Applications and SMiShing (SMS Phishing) [page 8, slide 26]
Fake Security Applications
SMiShing (SMS Phishing)
3.27 QRLJacking [page 9, slide 27]
3.28 Social Engineering Countermeasures [page 9, slide 29; page 10, slide 30]
Password Policies (slide 29)
Physical Security Policies (slide 29)
Defense Strategy (slide 29)
The 10 countermeasures (slide 30)
3.29 How to Defend against Phishing Attacks [page 10, slide 31]
3.30 Identity Theft Countermeasures [page 11, slide 32]
3.31 Anti-Phishing Toolbar: Netcraft and PhishTank [page 11, slide 34]
Netcraft
PhishTank
3.32 Audit Organization's Security for Phishing Attacks using OhPhish [page 12, slide 35]
3.33 Module Summary [page 12, slide 36]
3.34 Related Topics Not Shown in the Notes (ADDED CONTEXT)
Insider Threats
4. Tool Encyclopedia
4.1 Phishing and social engineering toolkits
4.2 QR, mobile, and AI-related tools
4.3 Defense, awareness, and reporting tools
4.4 Reconnaissance helpers for social engineering (added)
4.5 Look-alike tools and how to pick

5. Command Sheet
    5.1 setoolkit (Social-Engineer Toolkit) [page 6, slide 17]
    5.2 shellphish.sh (ShellPhish) [page 6, slide 17]
    5.3 Reading a QR code destination before scanning (ADDED CONTEXT)
    5.4 Checking the hosts file for pharming (ADDED CONTEXT) [relates to 3.18]
    5.5 nslookup (ADDED CONTEXT) [relates to 3.18]
    5.6 curl -I (ADDED CONTEXT) [relates to 3.17 and 3.31]
    5.7 sgpt (ShellGPT) for an AI-assisted social engineering defense task (ADDED CONTEXT)
    5.8 Checking app permissions before install (ADDED CONTEXT) [relates to 3.25 and 3.26]
    5.9 Hovering and inspecting a link without clicking (ADDED CONTEXT) [relates to 3.29]
6. Ports, Protocols, Standards and Acronyms
    6.1 Protocols and channels used by this module's techniques
    6.2 Standards, frameworks, and acronyms
7. Attack vs Countermeasure and Look-alike Comparisons
    7.1 Attacks with their countermeasures
    7.2 Look-alike pairs
8. Exam Cheat Sheet
    8.1 Keyword to answer
    8.2 Must-memorize lists
    8.3 Numbers and defaults
    8.4 Rules for picking the BEST option
9. Practice Questions
10. Flashcards
11. Glossary
12. Coverage Report
    12.1 Map of your pages to guide sections
    12.2 Items marked [UNCLEAR]
    12.3 Items to double check (verify)
    12.4 Coverage confirmation

Source: 12 pages of screenshots (24 slides, numbered P1-1 to P12-2 in reading order) from the official Module 09 theory videos. Content marked "ADDED CONTEXT" comes from outside the screenshots. Items marked "verify" should be checked against current official sources. Items marked [UNCLEAR on page N] were too small or blurry to read with full confidence. The printed slide numbers jump (2, 4, 5, 7, 9, 10, 11, 13, 15, 16, 17, 19, 22, 23, 25, 26, 27, 29, 30, 31, 32, 34, 35, 36), so some slides are not in the screenshots. Sections 3.3, 3.16, 3.22 and 3.34 add the missing background as ADDED CONTEXT.

1. Module at a Glance

Module: 09 - Social Engineering (EC-Council CEH v13 AI).

What this module is (5 lines):

1. Social engineering (SE) means tricking a person into giving away information or access. The target is the human, not the computer.
2. It works because people trust, obey, hurry, and want to help. No firewall can block that.
3. The module has three families of technique: human-based (face to face or by voice), computer-based (email, pop-ups, fake sites, AI fakes), and mobile-based (fake apps, SMS, QR codes).
4. It also covers phishing in depth (many named variants), identity theft, and impersonation on social networking sites.
5. It ends with countermeasures, anti-phishing toolbars (Netcraft, PhishTank), and the OhPhish simulation platform.

Why it matters: Most real breaches start with a person who clicked, answered, or held a door open. A strong firewall is useless if an employee gives the password to a caller. The notes say security is only as strong as its weakest link, and that link is human behavior.

What the exam usually asks from it:

- Match a short story to the technique: tailgating or piggybacking, vishing or phishing, baiting or quid pro quo, spear phishing or whaling.
- Name the phishing variant from its definition (pharming = DNS cache poisoning or host file change, spimming = spam over instant messaging, consent phishing = OAuth).
- Name the psychological trigger (authority, urgency, scarcity, greed, and so on).
- Pick the tool: SET for a toolkit, ShellPhish for social site credential pages, OhPhish for employee testing, Netcraft and PhishTank for anti-phishing.
- Mobile attack steps: malicious app, repackaged app, fake security app, SMiShing, QRLJacking.
- Pick the BEST countermeasure: usually training plus policy, not a single technical product.
- AI angle: deepfake video, voice cloning, and AI-written phishing.

The 10 things to remember most:

1. Social engineering = convincing people to reveal confidential information. It exploits human behavior, not software flaws.
2. Eight weak behaviors: authority, intimidation, consensus, scarcity, urgency, familiarity, trust, greed.
3. Impersonation is the most common human-based technique.
4. Piggybacking = the insider lets you in knowingly. Tailgating = you follow the insider without being noticed, often with a fake badge.
5. Reverse social engineering = the attacker becomes the authority and the victim comes to the attacker for help.
6. Spear phishing = specific person or small group. Whaling = top executives. Pharming = redirect traffic with DNS cache poisoning or host file change.
7. Spimming = spam over instant messaging. SMiShing = phishing over SMS. Vishing = phishing over voice calls.
8. Consent phishing abuses OAuth. Tabnabbing changes a background tab into a fake login. QRLJacking abuses "login with QR code".
9. Angler phishing = fake support account on social media. Catfishing = fake identity built for a relationship or fraud.
10. Defense = user awareness training, written policies with signed acknowledgement, two-factor authentication, spam filters, gap analysis, and phishing simulations (OhPhish).

2. Big Picture Map

Social engineering is a skill, not a single tool. The attacker picks a channel (person, computer, phone) and then a trick that fits the channel. The defense is the same in every case: aware people plus clear policy plus layered technical controls.

```
SOCIAL ENGINEERING (attack the person not the machine)
                        |
      +-------------------+--------------------+
      |                   |                    |
  HUMAN-BASED         COMPUTER-BASED        MOBILE-BASED
  by interaction      with computers        with mobile apps
      |                   |                    |
impersonation          phishing family       fake security apps
vishing                pop-up windows        malicious apps
eavesdropping          hoax and chain mails  repackaged apps
shoulder surfing       chat messenger        SMiShing
dumpster diving        spam mail             QRLJacking
reverse SE             scareware
piggybacking           deepfake video
tailgating             voice cloning
diversion theft
honey trap
baiting
quid pro quo
elicitation
```

How the topics connect to the rest of the course:

```
FOOTPRINTING -> SOCIAL ENGINEERING -> SYSTEM ACCESS
(Module 02)     (Module 09)        (passwords and malware)
    |               |                    |
names emails     trick a person to     Module 06 System Hacking
org charts       give data or access   Module 07 Malware Threats
                      |
                      v
              next is Module 10 Denial-of-Service
```

The module flow in the order of your screenshots:

```
1 Concepts -> 2 Human-based -> 3 Computer-based -> 4 Mobile
 (slide 4)    (slides 7-11)    (slides 13-23)     (slides 25-27)
                                          |
                                          v
7 Summary <- 6 Defense tools <- 5 Countermeasures <----+
(slide 36)   (slides 34-35)     (slides 29-32)
```

Table version of the map:

Channel	Core idea	Typical lure	Typical result
Human-based	Direct contact or observation	Badge, uniform, phone call	Secret, door access
Computer-based	Digital message or page	Email, pop-up, chat	Credentials, malware
Mobile-based	App, SMS, or QR code	Fake app, text message	Credentials, malware

3. Topic-by-Topic Guide

Each topic follows the same template. The tag in the heading shows the page and printed slide number of your screenshots, so you can match the guide to the video.

3.1 Learning Objectives [page 1, slide 2]

What it is: The module lists five goals. They are also the five blocks of the module.

No.	Objective on the slide	Where in this guide
01	Summarize social engineering concepts	3.2 and 3.3
02	Explain various human-based techniques	3.4 to 3.16
03	Explain various computer-based techniques	3.17 to 3.24
04	Explain various mobile-based techniques	3.25 to 3.27
05	Explain social engineering countermeasures	3.28 to 3.32

EXAM FOCUS: The exam does not ask about this slide. Use it as your study order: concepts, human, computer, mobile, countermeasures.

Memory trick: "C-H-C-M-C": Concepts, Human, Computer, Mobile, Countermeasures.

3.2 What is Social Engineering? [page 1, slide 4]

What it is (simple words): Social engineering is the art of convincing people to reveal confidential information. The attacker does not break a system. The attacker talks, writes, or acts until a person hands over the secret. It depends on one fact: people are often unaware of how valuable their information is, and they are careless about protecting it.

Analogy: A burglar can pick a lock, or he can wear a delivery uniform and ask the owner to open the door. Social engineering is the second way. The lock is never touched.

How it works (numbered steps):

1. The attacker gathers facts about the target (names, roles, habits). This is footprinting from Module 02.
2. The attacker chooses a human weakness to press (trust, fear, greed, urgency).
3. The attacker builds a believable story (a pretext) and a channel (call, email, visit).
4. The victim complies: gives data, opens a door, clicks a link, or installs something.
5. The attacker uses the result: logs in, enters the building, or installs malware.

Behaviors vulnerable to attacks (slide list, each explained):

Behavior	What the attacker does	Example line
Authority	Pretends to be a boss or official	"This is the CEO. Send it now."
Intimidation	Threatens a bad outcome	"Your account will be closed and you will be blamed."
Consensus	Says everyone else already did it	"All other departments have already sent theirs."
Scarcity	Says the offer is almost gone	"Only 5 licences left. Confirm today."
Urgency	Demands action right now	"The server is down. I need your login at once."
Familiarity	Acts like a friend or known person	"Hi, we met at the conference."
Trust	Builds a relationship first	Weeks of friendly chat, then a request
Greed	Offers a prize or money	"You won a gift card. Enter your details."

Factors that make companies vulnerable (slide list):

1. Insufficient security training. Staff do not know the tricks.
2. Unregulated access to information. Anyone can read anything.
3. Several organizational units. More branches mean more weak spots and slow communication.
4. Lack of security policies. No rule says what to share and with whom.

Why is social engineering effective? (slide list):

1. Security policies are as strong as their weakest link, and human behavior is the most susceptible factor.
2. It is difficult to detect social engineering attempts. A good lie looks like a normal request.
3. No method can be applied to ensure complete security from social engineering attacks.
4. No specific software or hardware exists to defend against a social engineering attack.

Real-world use: A tester is hired to check a bank branch. She phones the help desk, claims to be a traveling manager who forgot her password, and sounds stressed. The help desk resets the password. The result in the report: the policy existed, but nobody followed it. The fix is training and a call-back rule.

Tools and commands used here: None. This is concept only. Tools appear later (SET, ShellPhish, OhPhish).

AI angle: AI lowers the cost of a convincing story. A language model can write a flawless email in any language and any tone. Defenders can use AI to draft awareness training and to

classify suspicious messages. Example prompt (defender): "Write a 5-question quiz for non-technical staff that teaches them to spot urgency and authority tricks in emails."

Countermeasures and defense: Training, written policies, least privilege (give only the access that is needed), a way to verify identity (call-back), and a culture where reporting a mistake is safe.

EXAM FOCUS:

- Keywords: "weakest link", "human behavior", "convincing people", "no specific software or hardware".
- Common trap: choosing a technical control (firewall, IDS) as the complete answer. The slide says no specific software or hardware fully defends.
- Look-alike confusion: Authority vs Intimidation. Authority = "I am your boss". Intimidation = "bad things happen if you refuse". Scarcity vs Urgency. Scarcity = limited supply. Urgency = limited time.

> **EXAM TIP:** If a scenario says "the victim felt they had to obey a senior person", the trigger is authority. If it says "the victim was afraid of the consequences", the trigger is intimidation.

Memory trick: "A-I-C-S-U-F-T-G" -> "All Intelligent Clerks Should Understand Fake Tricks Gradually". Or remember the pairs: AI (Authority, Intimidation), CS (Consensus, Scarcity), UF (Urgency, Familiarity), TG (Trust, Greed).

3.3 Types of Social Engineering [page 2, slide 5]

What it is (simple words): The slide splits social engineering into three types by the way information is gathered.

Type	How information is gathered	Short name
Human-based	By interaction	People to people
Computer-based	With the help of computers	Digital tricks
Mobile-based	With the help of mobile apps	Phone and app tricks

Techniques named on the slide:

- **Human-based (14):** Impersonation, Vishing, Eavesdropping, Shoulder Surfing, Dumpster Diving, Reverse Social Engineering, Piggybacking, Tailgating, Diversion Theft, Honey Trap, Baiting, Bait and Switching, Quid Pro Quo, Elicitation.
- **Computer-based (7):** Pop-up Window, Phishing, Instant Chat Messenger, Spam Mail, Scareware, Create Deepfake Videos, Voice Cloning.
- **Mobile-based (5):** Using Fake Security Apps, Publishing Malicious Apps, SMiShing (SMS Phishing), Repackaging Legitimate Apps, QRLJacking.

Analogy: Think of three doors into a house. The front door is a person (human-based). The window is the computer (computer-based). The phone line is the mobile route (mobile-based). The burglar picks the easiest one.

How it works: The attacker first picks a channel. Then he picks a technique that fits the channel and the target. Many real attacks mix channels. For example, a phishing email (computer) can tell the victim to call a number (vishing, human).

Real-world use: A red team tests a company. They send phishing emails (computer-based), call the help desk (human-based vishing), and drop USB sticks in the car park (human-based baiting). The report shows which channel failed first.

Tools and commands used here: None at this level. Tools are listed per technique below.

AI angle: Two items on this slide are AI-powered: Create Deepfake Videos and Voice Cloning. They are covered in section 3.22.

Countermeasures and defense: Defend every channel: physical controls for human-based, email and web filters for computer-based, app store policy and mobile device management (MDM) for mobile-based. Section 3.28 has the full list.

EXAM FOCUS:

- The exam asks "which type is this?". Rule: if the attacker talks to or watches a person, it is human-based. If the lure arrives through a computer, it is computer-based. If an app, SMS, or QR code on a phone is the lure, it is mobile-based.
- Common trap: Vishing is listed under human-based even though it uses a phone. The exam treats it as human-based because a person talks to a person.
- Common trap: SMiShing is mobile-based, phishing is computer-based. The channel decides.

Memory trick: "H-C-M" = Human, Computer, Mobile. For the mobile list, remember "F-P-S-R-Q": Fake security apps, Publishing malicious apps, SMiShing, Repackaging, QRLJacking.

> **ADDED CONTEXT:** Phases of a social engineering attack. Many courseware versions describe four phases: (1) Research the target, (2) Select the victim, (3) Develop a relationship, (4) Exploit the relationship. Some sources also add a clean-up step. Your screenshots do not show this slide, so treat it as extra. Memory trick: "R-S-D-E".

3.4 Impersonation [page 2, slide 7]

What it is (simple words): The attacker pretends to be someone legitimate or an authorized person. He may do this in person or by a communication medium such as phone or email. Impersonation tricks the target into revealing sensitive information. The slide states it is the most common human-based social engineering technique.

Analogy: A stranger wearing a hi-vis jacket and carrying a clipboard can walk into most buildings. People assume the jacket means permission.

How it works (numbered steps):

1. The attacker learns names, titles, and internal words from open sources.
2. He picks a role that the victim will not question.
3. He contacts the victim by phone, email, or in person and uses the role.
4. He asks for a password, an ID, a reset, or physical access.
5. The victim helps because the role looks real.

The three impersonation examples on the slide:

Quotes from the slide, with the trigger each one uses:

- **Legitimate end user.** Quote: "Hi! This is John from the Finance Department. I have forgotten my password. Can I get it?" Trigger: familiarity and the wish to help.
- **Important user (VIP).** Quote: "Hi! This is Kevin, CFO Secretary. I'm working on an urgent project and lost my system's password. Can you help me out?" Trigger: authority and urgency.
- **Technical support agent.** Quote: "Sir, this is Matthew, Technical Support, X company. Last night we had a system crash here, and we are checking for the lost data. Can you give me your ID and password?" Trigger: authority and fear of data loss.

Reading the three rows:

- **Posing as a legitimate end user:** the attacker gives this identity and asks for the sensitive information.
- **Posing as an important user:** the attacker poses as a VIP of a target company or a valuable customer.
- **Posing as technical support:** the attacker poses as technical support staff and asks for IDs and passwords.

Real-world use: A tester phones a help desk, claims to be the CFO's secretary, and says the boss is in a meeting and needs a password reset now. The help desk resets it without a check. The result: the tester logs in as the user. The report recommends identity checks before any reset.

Tools and commands used here: None needed. Caller ID spoofing tools exist (ADDED CONTEXT). Open-source research (LinkedIn, company website) supplies the names.

AI angle: AI can copy a manager's writing style from public posts, and a cloned voice can make the phone call sound real (see 3.22). Example prompt (defender, training): "Write three short role-play scripts of an attacker posing as IT support, so I can train the help desk to spot them."

Countermeasures and defense: Verify identity through a second channel (call back on the number in the company directory, not the number the caller gives). Never share passwords with anyone, including IT. Use a help desk checklist. Give badges and require visitor escorts.

EXAM FOCUS:

- Keywords: "pretends to be", "authorized person", "VIP", "technical support", "forgot my password".
- Common trap: confusing impersonation with phishing. Impersonation is the broad technique. Phishing is impersonation by email.
- Look-alike: Impersonation vs Reverse social engineering. In impersonation the attacker contacts the victim. In reverse social engineering the victim comes to the attacker.

> **EXAM TIP:** "Most common human-based technique" -> Impersonation.

Memory trick: The three roles are "U-V-T": User, VIP, Tech support. Story: John (user), Kevin (VIP), Matthew (tech). J-K-M.

3.5 Eavesdropping [page 3, slide 9]

What it is (simple words): Eavesdropping is unauthorized listening to conversations or reading of messages. It also covers interception of audio, video, or written communication. It can use communication channels such as telephone lines, email, and instant messaging.

Analogy: Standing at a thin wall and listening to the neighbours. You never speak to them. You only collect what they say.

How it works (numbered steps):

1. The attacker finds a place or channel where people share information (a phone line, a chat, an open office, a coffee shop).
2. He listens, records, or reads without being noticed.
3. He collects names, numbers, plans, and passwords.
4. He uses what he learned for a later attack.

Real-world use: An attacker sits near a company's lunch area and hears two staff discuss a vendor name and an invoice process. Later he sends a fake invoice from "that vendor". The result: a payment to the attacker.

Tools and commands used here: None are named on the slide. In the network sense, eavesdropping is done with sniffers (Module 08), for example Wireshark (ADDED CONTEXT).

AI angle: AI speech-to-text can turn hours of recorded audio into searchable text in minutes. That makes passive listening more productive for an attacker.

Countermeasures and defense: Hold sensitive talks in private rooms. Encrypt calls, email, and chat (TLS, end-to-end encryption). Do not discuss secrets in public. Sweep meeting rooms for bugs (ADDED CONTEXT: technical surveillance countermeasures).

EXAM FOCUS:

- Keywords: "unauthorized listening", "interception of audio, video, or written communication", "telephone lines".
- Common trap: Eavesdropping is passive. The attacker does not talk to the victim.
- Look-alike: Eavesdropping vs Shoulder surfing. Eavesdropping = hearing or intercepting communication. Shoulder surfing = seeing what is typed or shown.

Memory trick: "Ears" = Eavesdropping uses ears. "Eyes" = shoulder surfing uses eyes.

3.6 Shoulder Surfing [page 3, slide 9]

What it is (simple words): Shoulder surfing is direct observation. The attacker looks over someone's shoulder to get information such as passwords, PINs, and account numbers. It can also be done from a distance using vision-enhancing devices such as binoculars.

Analogy: Watching a friend type a phone passcode on a bus. You never touch the phone, but you now know the code.

How it works (numbered steps):

1. The attacker stands or sits where the screen or keypad is visible.
2. He watches the typing or the screen.
3. He remembers or records the data (note, photo, video).
4. He uses the data to log in or to withdraw money.

Real-world use: At an airport lounge, a person watches a traveler enter a laptop password. Later the laptop is stolen. The thief unlocks it in seconds. The result: data loss. Privacy screen filters and short auto-lock would have reduced the risk.

Tools and commands used here: Binoculars or cameras (slide). Nothing digital is needed.

AI angle: AI video tools can read key presses from a recorded video of hand movements or from audio of typing (research topic, ADDED CONTEXT). This makes a distant camera more dangerous.

Countermeasures and defense: Use privacy screen filters. Shield PIN pads. Do not enter secrets in public places. Use biometric or hardware-key login. Lock the screen when you leave. Position screens away from windows and walkways.

EXAM FOCUS:

- Keywords: "looking over someone's shoulder", "binoculars", "PINs", "vision enhancing devices".

- Common trap: Shoulder surfing can happen at a distance. It does not need to be close.
- Look-alike: Shoulder surfing vs Dumpster diving. One watches live data. The other searches discarded data.

Memory trick: "Shoulder = Sight". Binoculars = far shoulder.

3.7 Dumpster Diving [page 3, slide 9]

What it is (simple words): Dumpster diving means looking for treasure in someone else's trash. It involves collecting phone bills, contact information, financial information, and operations-related information from the target company's trash bins, printer bins, or user desks (for example sticky notes).

Analogy: A detective who reads your torn-up letters. What you consider rubbish still tells a story.

How it works (numbered steps):

1. The attacker finds out the trash collection day and the location of the bins.
2. He collects bags or checks printer bins and desks.
3. He sorts the paper and devices for useful items (bills, org charts, passwords on sticky notes, old disks).
4. He uses the facts to build a believable pretext for another attack.

Real-world use: A tester finds an old phone directory and a printed network diagram in a recycling bin. She uses the names to impersonate a department head on the phone. The result: a successful pretext. The report advises shredding.

Tools and commands used here: None. Gloves and a bag. This is physical.

AI angle: AI-based OCR (optical character recognition) can scan hundreds of recovered pages quickly and extract names, numbers, and emails into a searchable list.

Countermeasures and defense: Shred paper (cross-cut shredders). Use locked disposal bins. Wipe or destroy old drives and media. Run a clean-desk policy. Keep bins inside secured areas.

EXAM FOCUS:

- Keywords: "trash", "phone bills", "sticky notes", "printer bins", "treasure".
- Common trap: Dumpster diving is not always illegal in the real world, but it is still a social engineering technique and a reconnaissance method. The exam treats it as an attack method.
- Look-alike: Dumpster diving vs Diversion theft. Dumpster diving takes discarded items. Diversion theft redirects a real delivery.

Memory trick: "Dive for D-C-F-O": Documents, Contacts, Finance, Operations info.

3.8 Reverse Social Engineering [page 3, slide 10]

What it is (simple words): The attacker presents himself or herself as an authority, and the target seeks his or her advice before or after the attacker offers the information that is needed. The victim contacts the attacker. This is the opposite of normal social engineering, where the attacker contacts the victim.

Analogy: A mechanic secretly loosens a wheel nut on your car, then puts up a sign "Free repairs here". You walk to him, trust him, and tell him everything.

How it works (the classic three steps; ADDED CONTEXT for the sub-steps):

1. Sabotage. The attacker causes a small problem (for example disables a service or plants a fault) or simply waits for one.
2. Marketing. The attacker advertises himself as the person who can fix it (business card, email, a poster).
3. Support. The victim calls the attacker. The attacker "helps" and asks for IDs, passwords, or access as part of the fix.

Real-world use: An attacker blocks a network printer, leaves a card saying "IT help: call this number", and waits. An employee calls and gives a login to "fix" the printer. Result: valid credentials.

Tools and commands used here: None. It is a human technique. Fake business cards and spoofed phone numbers are props.

AI angle: AI chatbots can run the fake "help desk" at scale and sound professional. Example prompt (defender): "List five signs that an unexpected IT helper who called me first might be an attacker."

Countermeasures and defense: Staff must use only the official help desk number. Verify any helper. Report strange outages to security. Do not share credentials during support, use remote-support tools that log in with a managed account.

EXAM FOCUS:

- Keywords: "presents himself as an authority", "target seeks advice", "before or after".
- Common trap: The victim initiates the contact. If the attacker calls first, it is impersonation, not reverse social engineering.
- Look-alike: Reverse SE vs Quid pro quo. In reverse SE, a created problem makes the victim come. In quid pro quo, the attacker makes many random calls and offers help for data.

Memory trick: "Reverse = the victim goes to the attacker." Think "reverse the call direction".

3.9 Piggybacking [page 3, slide 10]

What it is (simple words): An authorized person intentionally or unintentionally allows an unauthorized person to pass through a secure door. The slide example is: "I forgot my ID badge at home. Please help me."

Analogy: A friendly person holds the door for you at the office because you look lost and polite.

How it works (numbered steps):

1. The attacker waits near a secure door.
2. He asks an employee for help, often with a story (forgot badge, hands full).
3. The employee badges in and lets him through.
4. The attacker is now inside with the employee's consent.

Real-world use: A tester carries two coffees and says "my hands are full, can you hold the door?". The employee does. The tester walks to the server room corridor. Result: physical access gained and logged in the report.

Tools and commands used here: None. Props: coffee, boxes, a lanyard.

AI angle: Not directly. AI-generated fake badges (images) can help tailgating (see 3.10).

Countermeasures and defense: Policy: one badge swipe per person. Security guards. Mantraps (also called airlock or access control vestibule: two doors where the second door only opens after the first closes). Train staff to politely refuse and to escort visitors to reception.

EXAM FOCUS:

- Keywords: "authorized person allows", "forgot my ID badge", "please help me", "intentionally or unintentionally".
- Common trap: Piggybacking has the insider's consent (the insider knowingly holds the door).
- Look-alike: Piggybacking vs Tailgating (see the pair table in 3.10).

Memory trick: "Piggy back = a ride you are given." The insider gives the ride.

3.10 Tailgating [page 3, slide 10]

What it is (simple words): The attacker, wearing a fake ID badge, enters a secured area by closely following an authorized person through a door that requires key access. The insider may not notice.

Analogy: Slipping through a train gate right behind a passenger, before the gate closes.

How it works (numbered steps):

1. The attacker prepares a fake ID badge that looks real from a distance.
2. He waits for an employee to approach a badge door.
3. He follows closely behind the employee as the door opens.
4. He walks in before the door shuts. The employee often assumes the badge means he belongs.

Real-world use: A tester prints a copy of a visible badge design, clips it to a jacket, and follows a group into a building. Result: access to the floor. The control that failed was a door with no anti-passback or camera alert.

Tools and commands used here: Fake ID badge (printed card). ADDED CONTEXT: badge cloners and RFID readers exist for stronger attacks; they belong to physical penetration testing.

AI angle: AI image tools can create realistic badge images or logos quickly. Defenders can use AI video analytics to count people per badge swipe and flag two people entering on one swipe.

Countermeasures and defense: Mantraps, turnstiles that allow one person at a time, guards, cameras with people-counting, visible color-coded badges, and a culture that challenges strangers.

EXAM FOCUS:

- Keywords: "fake ID badge", "closely following", "key access".
- Common trap: The exam often gives a story where an employee knowingly holds the door (piggybacking) and one where the attacker sneaks in behind (tailgating). Read who is aware.

Piggybacking vs Tailgating in one place:

Point	Piggybacking	Tailgating
Insider aware?	Yes, lets the person in	Often no, or assumes badge is real
Attacker's tool	A story ("forgot my badge")	A fake ID badge
Core action	Insider holds the door	Attacker follows closely
Consent	Given (even if tricked)	Not clearly given

> **TRAP:** Many study sources mix these two terms. In your notes, piggybacking is "an authorized person allows" and tailgating is "fake ID badge and following". Use the notes' definitions on the exam.

Memory trick: "Piggyback = permission. Tailgate = trick the gate."

3.11 Diversion Theft [page 3, slide 10]

What it is (simple words): The attacker tricks a person responsible for making a genuine delivery into delivering the consignment (package, goods) to a location other than the intended location.

Analogy: Someone phones the courier and says "change the address to the shop around the corner", and the parcel arrives at the thief's door.

How it works (numbered steps):

1. The attacker learns about an expected delivery (valuable goods, documents, devices).
2. He contacts the courier or the dispatcher and poses as the customer or manager.
3. He gives a new delivery address or pickup point.
4. The courier delivers to the wrong place, and the attacker takes the goods.

Real-world use: A criminal watches a company that orders laptops. He phones the courier posing as the office manager and redirects the parcel to a nearby address. Result: stolen laptops (and possibly stolen data on them).

Tools and commands used here: None. Phone and a believable story.

AI angle: Voice cloning can mimic the office manager's voice for the call to the courier.

Countermeasures and defense: Delivery change requests must be verified with the original sender through a known contact. Use signed delivery receipts. Track shipments. Restrict who can change delivery details.

EXAM FOCUS:

- Keywords: "genuine delivery", "location other than the intended location", "consignment".
- Common trap: Diversion theft is about redirecting a real delivery, not stealing trash and not stealing through the door.
- Look-alike: Diversion theft vs Baiting. Baiting leaves an item for the victim to pick up. Diversion theft redirects something the victim expects.

Memory trick: "Diversion = Detour". The parcel takes a detour.

3.12 Honey Trap [page 4, slide 11]

What it is (simple words): Attackers target a person inside the company online, pretending to be an attractive person. They begin a fake online relationship to obtain confidential information about the target company.

Analogy: A fisherman uses a shiny lure. The fish thinks it is food. Here the lure is romance.

How it works (numbered steps):

1. The attacker finds an employee with access to useful information (from a social site).

2. He creates a fake attractive profile with stolen photos.
3. He starts a friendly chat and builds an emotional bond.
4. Over time he asks questions about work, projects, or access.
5. The victim shares confidential information because of the bond.

Real-world use: A "recruiter" with a model's photo befriends an engineer on a professional network and slowly asks about the product roadmap. Result: leaked plans.

Tools and commands used here: None. Fake social profiles. Compare with catfishing in 3.23.

AI angle: AI can generate profile photos of people who do not exist and write warm, consistent chat messages. A reverse image search often fails against AI-made faces. Example prompt (defender): "Give me a checklist to verify whether a new online contact is real."

Countermeasures and defense: Policy on sharing work details online. Do not accept contact requests from unknown people. Report odd approaches. Reverse image search a profile photo. Training on romance-based social engineering.

EXAM FOCUS:

- Keywords: "attractive person", "fake online relationship", "confidential information".
- Common trap: A honey trap targets a person inside the company, using emotion. It is not the same as a honeypot (a decoy system, Module 12).
- Look-alike: Honey trap vs Catfishing. Honey trap aims at corporate secrets. Catfishing (slide 22) aims at identity theft, harassment, or money from a person.

> **TRAP:** Honey trap (a person) vs honeypot (a trap system for attackers, Module 12). Different things.

Memory trick: "Honey attracts. Love is the lure."

3.13 Baiting (and Bait and Switching) [page 4, slide 11; page 2, slide 5]

What it is (simple words): Attackers offer end users something alluring in exchange for important information, such as login details and other sensitive data. The slide also describes a physical version: a device such as a USB flash drive that contains malicious files is left in a place where people can easily find it.

Analogy: A wallet dropped on a street. A curious person picks it up to find the owner and gets caught.

How it works (numbered steps):

1. The attacker loads a USB drive with malware, or builds a "free offer" page.
2. He labels it with an attractive tag ("Salary 2026", "Confidential") or advertises a prize.
3. He leaves the drive in a car park, lobby, or lift, or sends the offer.

4. A curious victim plugs in the drive or enters login details.
5. The malware runs, or the details reach the attacker.

Real-world use: A tester leaves ten USB drives near a company entrance. Four are plugged into office PCs. A harmless beacon file reports each plug-in. The report shows the need for USB controls.

Tools and commands used here: USB drives. ADDED CONTEXT: USB Rubber Ducky and similar devices type malicious commands fast as a fake keyboard; Social-Engineer Toolkit (SET) can build payloads (see 3.20).

AI angle: AI can write the temptation text ("Q4 bonus list") tuned to each department.

Countermeasures and defense: Disable USB ports or allow only approved devices. Turn off autorun. Scan removable media in a sandbox. Train staff never to plug in unknown media. Hand found drives to IT.

> **ADDED CONTEXT:** Bait and Switching. It appears in the slide 5 technique list but has no detail slide in your screenshots. Meaning: the attacker first offers something good (the bait), such as a free download, a job offer, or an ad. After the victim engages, the attacker swaps it for something harmful (the switch), such as malware or a fake login page. Treat it as baiting where the good offer is replaced with a harmful one.

EXAM FOCUS:

- Keywords: "USB flash drive left in a location", "alluring", "login details".
- Common trap: Baiting depends on curiosity or greed. The victim is not contacted directly.
- Look-alike: Baiting vs Quid pro quo. Baiting offers an item. Quid pro quo offers a service (usually help) in exchange for data.

Memory trick: "Bait = found USB." Fishing: the lure is the USB.

3.14 Quid Pro Quo [page 4, slide 11]

What it is (simple words): Attackers call numerous random numbers within a company, claiming to be from technical support. They offer their service to end users in exchange for confidential data or login credentials. "Quid pro quo" is Latin for "something for something".

Analogy: A door-to-door "repairman" offers a free check of your home in return for letting him inside.

How it works (numbered steps):

1. The attacker gets a list of phone extensions in a company.
2. He calls many numbers, saying "this is IT support".
3. Sooner or later a user really has a problem and accepts the help.

4. The attacker asks for credentials or asks the user to disable security software.
5. The user pays with data for the "service".

Real-world use: An attacker calls 50 extensions. The 12th user has a slow PC. The caller "fixes" it by asking the user to install a remote tool. Result: remote access to the PC.

Tools and commands used here: Phone and a call list. ADDED CONTEXT: remote-access tools are misused as the "fix".

AI angle: AI voice agents can place hundreds of calls and adapt their script. Defenders can use AI call analytics to flag unusual calls.

Countermeasures and defense: Staff must know the real IT support process. IT never asks for passwords. Verify via the official help desk. Report unsolicited support calls.

EXAM FOCUS:

- Keywords: "numerous random numbers", "claiming to be from technical support", "in exchange for".
- Common trap: The attacker offers a service. If the attacker offers an object, it is baiting.
- Look-alike: Quid pro quo vs Reverse SE (see 3.8).

Memory trick: "Quid = Questionable help calls." Many calls, one lucky hit.

3.15 Elicitation [page 4, slide 11]

What it is (simple words): Attackers extract information from the victim by engaging him or her in normal and disarming conversation. Based on the victim's interests, attackers must work to target their elicitation approach to extract the relevant information.

Analogy: A friendly chat at a party where one person asks gentle questions and keeps you talking. You leave and realise you told too much.

How it works (numbered steps):

1. The attacker studies the victim's interests and job.
2. He starts a casual talk on a shared interest.
3. He uses soft techniques: flattery, false statements to be corrected, open questions, and showing interest.
4. The victim talks freely.
5. The attacker steers toward the target topic and collects facts.

Real-world use: At a trade show, an attacker says "I heard your company still uses an old billing system, it must be painful". The proud engineer corrects him and names the system and version. Result: a useful fact for a later attack.

Tools and commands used here: None. Interpersonal skill.

AI angle: AI chat tools can suggest conversation openers by analysing a target's public posts and interests. Defenders can use the same data to measure how much a person reveals.

Countermeasures and defense: Teach staff what is confidential. Use polite deflection ("I can't discuss that"). Brief staff before conferences. Keep talk about work on approved channels.

EXAM FOCUS:

- Keywords: "normal and disarming conversation", "interests".
- Common trap: Elicitation does not use threats or tools. It is subtle conversation.
- Look-alike: Elicitation vs Eavesdropping. In elicitation the attacker talks to the victim. In eavesdropping the attacker only listens.

Memory trick: "Elicit = Extract through Easy chat."

3.16 Vishing [page 2, slide 5; no detail slide in the notes]

> **ADDED CONTEXT:** Vishing is on the slide 5 technique list under human-based techniques, but your screenshots have no detail slide for it. The explanation below is added knowledge.

What it is (simple words): Vishing means voice phishing. The attacker phones the victim, or leaves a voice message, and pretends to be a bank, a government office, or tech support. The aim is to get account numbers, PINs, one-time passwords, or money.

Analogy: A phishing email, but spoken. The bait is a voice.

How it works (numbered steps):

1. The attacker spoofs the caller ID so the call looks like it comes from a trusted number.
2. The caller states a problem (suspicious transaction, tax debt, locked account).
3. He adds pressure (urgency, fear).
4. The victim gives card data, an OTP (one-time password), or installs software.
5. The attacker drains the account or logs in.

Real-world use: A "bank" calls and says "someone is trying to withdraw your money, read me the code we just sent". The code is a real login OTP. Result: account takeover.

Tools and commands used here: Caller ID spoofing services and VoIP (voice over IP) systems. ADDED CONTEXT.

AI angle: Voice cloning (3.22) lets a vishing call sound like a known person. A real-world pattern is the "CEO fraud" call that asks finance staff to transfer money.

Countermeasures and defense: Never share OTPs or PINs on a call. Hang up and call back on the official number. Banks should state they never ask for full PINs. Use a family or team code word for urgent money requests.

EXAM FOCUS:

- Keywords: "voice", "phone call", "VoIP", "caller ID".
- Common trap: Vishing is phishing by voice. SMiShing is phishing by SMS.
- Look-alike: Vishing vs Impersonation. Vishing is impersonation done by phone.

Memory trick: "V = Voice. S = SMS. Ph = email/pages."

3.17 Phishing [page 4, slide 13]

What it is (simple words): Phishing is the practice of sending an illegitimate email that claims to be from a legitimate site, in an attempt to acquire a user's personal or account information. Phishing emails or pop-ups redirect users to fake webpages that mimic trustworthy sites, which then ask them to submit their personal information.

Analogy: Fishing with bait. The email is the bait, the fake page is the hook, and the password is the fish.

How it works (numbered steps):

1. The attacker copies the look of a real brand (logo, colors, wording).
2. He sends an email that creates a reason to click (a document waiting, a payment problem).
3. The link opens a fake page that looks like the real login page.
4. The victim types a user name and password.
5. The page sends the data to the attacker and often forwards the victim to the real site so nothing looks wrong.

```
ATTACKER --(fake email)--> VICTIM --(click link)--> FAKE LOGIN PAGE
  ^                                  |
  |                                  v
  +------(stolen user name and password)----------------+
```

The slide example: A fake DocuSign email with the subject "Completed Benefit Package For [REDACTED]". It shows a DocuSign-style box, "Your document has been completed", and a "VIEW COMPLETED DOCUMENT" button. The note on the slide says clicking the link directs you to a fraudulent web page that looks similar to a genuine Microsoft page. The fake page shows a Microsoft-style "Enter password" box. The web address on the fake page is small and hard to read [UNCLEAR on page 4], which is exactly the point: a victim who does not check the address is caught.

Real-world use: An employee receives a document-signing email on a busy Friday. She clicks, sees a Microsoft sign-in, and enters her password. The attacker now reads her mail. The report finds that the sender domain did not match DocuSign and the link domain was unrelated to Microsoft.

Tools and commands used here: SET, ShellPhish, Gophish (3.20). Defensive tools: Netcraft, PhishTank (3.31), OhPhish (3.32).

AI angle: AI writes grammar-perfect phishing text in any language, which removes the old warning signs of spelling mistakes. Malicious chatbots sold on criminal forums (WormGPT and FraudGPT are the names most often cited, ADDED CONTEXT, verify) are marketed for this. Defenders use AI mail filters that read the context and tone. Example prompt (defender): "Analyse this email header and body. List the signs of phishing and rate the risk from 1 to 5."

Countermeasures and defense: See 3.29. In short: spam filters, hover over links, check the sender, use HTTPS, two-factor authentication, and training with simulated phishing.

EXAM FOCUS:

- Keywords: "illegitimate email", "legitimate site", "fake webpages", "mimic trustworthy sites".
- Common trap: Phishing is broad (mass, not targeted). Spear phishing is targeted.
- Look-alike: Phishing vs Pharming. Phishing needs the victim to click a lure. Pharming redirects the victim even when the correct address is typed.

> **EXAM TIP:** If a question mentions a "generic salutation" such as "Dear customer", think mass phishing. If it uses your name and job, think spear phishing.

Memory trick: "Phishing = Fake email + Fake page." PH replaces F because early hackers were "phone phreaks".

3.18 Types of Phishing [page 5, slide 15]

The slide lists four types here: Spear Phishing, Whaling, Pharming, Spimming.

Spear Phishing

What it is (simple words): A targeted phishing attack aimed at specific individuals within an organization. Attackers send spear phishing messages with specialized, social engineering content directed at a specific person or a small group of people.

Analogy: Normal phishing is a net that catches many fish. Spear phishing is a spear aimed at one fish.

How it works (numbered steps):

1. The attacker researches one person (name, boss, project, hobbies).
2. He writes a message using real details so it looks personal.
3. He sends it from a lookalike address or a hijacked account.
4. The victim clicks or opens an attachment.

5. The attacker gets credentials or installs malware.

Real-world use: An accountant receives an email that names her manager, mentions last week's audit, and attaches "Audit_Q3.xlsm". The attachment installs a backdoor.

Tools and commands used here: SET spear-phishing attack vector (3.20), Gophish.

AI angle: AI reads a target's public posts and writes a custom message in minutes. This makes spear phishing cheap at scale, sometimes called mass spear phishing.

Countermeasures and defense: Training on personalized lures, email authentication (SPF, DKIM, DMARC, ADDED CONTEXT), attachment sandboxing, macros disabled by default, and out-of-band confirmation for unusual requests.

EXAM FOCUS: Keywords: "specific individuals", "small group", "specialized content". Trap: do not pick "whaling" unless the target is a top executive.

Memory trick: "Spear = Single target."

Whaling

What it is (simple words): An attacker targets high-profile executives like CEOs, CFOs, politicians, and celebrities who have complete access to confidential and highly valuable information. The attacker tricks the victim into revealing critical corporate and personal information through email or website spoofing.

Analogy: A whale is a very big fish. One catch is worth a thousand small ones.

How it works (numbered steps):

1. The attacker picks a senior executive.
2. He studies public speeches, filings, and travel plans.
3. He sends a message styled as a legal notice, a subpoena, a board request, or a deal document.
4. The executive acts (opens, signs, authorises a payment).
5. The attacker gains high-level access or money.

Real-world use: A CFO gets a "board resolution" PDF from a spoofed chairman address. The attachment steals her login. The attacker then approves a wire transfer.

Tools and commands used here: Same toolset as spear phishing. Website spoofing pages that copy corporate portals.

AI angle: Deepfake voice or video of the CEO can support whaling-style fraud, where a finance clerk is told to pay urgently (see 3.22). This pattern is often called CEO fraud or business email compromise (BEC, ADDED CONTEXT).

Countermeasures and defense: Executive-specific training, strict dual approval for payments, verification calls on a known number, and email banners for external senders.

EXAM FOCUS: Keywords: "CEO", "CFO", "politicians", "celebrities", "high profile". Trap: whaling is a type of spear phishing aimed at the top; if the target is just an employee, pick spear phishing.

Memory trick: "Whale = Wealthy, Worthy, Well-placed executive."

Pharming

What it is (simple words): The attacker redirects web traffic to a fraudulent website by installing a malicious program on a personal computer or server. It is also known as "phishing without a lure". It is performed using DNS cache poisoning or host file modification.

Analogy: Someone secretly changes the road sign. You drive to the bank you wanted, but the sign sends you to a copy of the bank.

How it works (numbered steps):

1. The attacker poisons a DNS cache (it stores name-to-IP answers) or edits the victim's hosts file (a local name-to-IP list).
2. The wrong IP address is now stored for a real domain name.
3. The user types the correct web address.
4. The computer resolves the name to the attacker's IP.
5. The fake site loads, and the user enters credentials.

```
NORMAL    user -> DNS -> real IP -> real bank site
PHARMING  user -> poisoned DNS or hosts file
          -> attacker IP -> fake site
```

Real-world use: Malware adds a line to the hosts file mapping a bank's domain to an attacker IP. The user types the bank's address correctly and still lands on a copy. The report finds the changed hosts file.

Tools and commands used here: Hosts file inspection (`cat /etc/hosts` on Linux, `type C:\Windows\System32\drivers\etc\hosts` on Windows) and `nslookup` to compare answers. See section 5. Attack side (ADDED CONTEXT): ettercap and DNS spoofing tools (Module 08).

AI angle: AI is not needed for pharming. A defender can use anomaly detection on DNS logs to spot sudden changes in the answers for known domains.

Countermeasures and defense: Use DNSSEC (digital signatures on DNS answers), keep DNS servers patched, restrict zone caches, use anti-malware, protect the hosts file, and check TLS certificates (a fake site cannot get a valid certificate for the real domain).

EXAM FOCUS: Keywords: "redirects web traffic", "phishing without a lure", "DNS cache poisoning", "host file modification". Trap: the user did nothing wrong (typed the correct address). Look-alike: Pharming vs Phishing.

Memory trick: "Pharming = Farm the traffic: move the herd to another field."

Spimming

What it is (simple words): A variant of spam that exploits Instant Messaging platforms to flood spam across the networks. The attacker uses bots to harvest Instant Message IDs and spread spam. The word is a mix of "spam" and "IM" (instant messaging). It is also spelled SPIM.

Analogy: Junk mail, but delivered into your chat window.

How it works (numbered steps):

1. A bot collects IM user IDs from public lists, directories, and profiles.
2. The bot sends messages with links or attachments to all IDs.
3. Some users click and land on phishing pages or download malware.
4. Infected accounts may then spam their own contacts.

Real-world use: Staff receive "check this photo" messages from unknown IDs on a chat app. One user clicks and installs a trojan. The company then blocks unknown senders on the chat platform.

Tools and commands used here: Bots (no tool is named on the slide).

AI angle: AI chatbots make spimming messages look like real conversations and respond to replies, which makes bots harder to spot.

Countermeasures and defense: Block messages from unknown contacts, turn off auto-download, rate-limit new accounts, filter links, and educate users not to click links in unsolicited chats.

EXAM FOCUS: Keywords: "instant messaging", "bots harvest IM IDs". Trap: spimming is not SMS spam (that is SMiShing) and not email spam. Look-alike: Spam vs Spimming: the channel differs.

Memory trick: "SPIM = SPam + IM."

3.19 Types of Phishing, continued [page 5, slide 16]

The slide lists five more types: Clone Phishing, E-wallet Phishing, Tabnabbing and Reverse Tabnabbing, Consent Phishing, Search Engine Phishing.

Clone Phishing

What it is (simple words): An attacker creates a nearly identical copy of a legitimate communication, which contains a link or attachment and may have been previously received in its original form. The attacker modifies certain elements, typically the link or attachment, to point to a malicious destination.

Analogy: A forger copies a real letter you already received and only changes the bank account number at the bottom.

How it works (numbered steps):

1. The attacker obtains a real email that the victim got earlier.
2. He copies it word for word.
3. He replaces the link or attachment with a malicious one.
4. He resends it, often saying "resending with the updated link".
5. The victim trusts it because it matches the original.

Real-world use: A vendor invoice email is cloned. The new copy has a changed payment link. The finance team pays the attacker.

Tools and commands used here: Email clients and spoofing tools. Gophish can template cloned mails (3.20).

AI angle: AI can tweak a cloned email to avoid spam filters by paraphrasing while keeping the meaning.

Countermeasures and defense: Treat "resent" mails with care. Verify with the sender. Hover over links. Check the real sender address.

EXAM FOCUS: Keywords: "nearly identical copy", "previously received", "replaced link or attachment". Trap: the original email was genuine; the clone is the attack.

Memory trick: "Clone = Copy of a real mail."

E-wallet Phishing

What it is (simple words): An attacker targets users of electronic wallets by sending a phishing email or messages to potential victims, posing as a legitimate e-wallet provider. An e-wallet is an app or account that stores payment details or digital money.

Analogy: A fake bank clerk who stands at the door of the wallet shop and asks for your PIN.

How it works (numbered steps):

1. The attacker finds users of a given wallet service.
2. He sends a message that looks like the provider ("verify your account", "reward waiting").
3. The link opens a fake login or asks for a recovery phrase or PIN.
4. The victim submits secrets.
5. The attacker moves the funds.

Real-world use: A text says "Your wallet is limited. Confirm here". The user enters the one-time code. The attacker empties the balance.

Tools and commands used here: Phishing kits and sites (concept only).

AI angle: AI can generate brand-matched messages in the user's language. Defenders use AI fraud scoring on wallet transactions.

Countermeasures and defense: Use two-factor authentication, never share recovery phrases or OTPs, open the wallet app directly instead of using links, and check official sender channels.

EXAM FOCUS: Keywords: "electronic wallets", "posing as a legitimate e-wallet provider". Trap: do not confuse with mobile app attacks; the key is the wallet brand.

Memory trick: "E-wallet = Electronic wallet raid."

Tabnabbing and Reverse Tabnabbing

What it is (simple words): In a tabnabbing attack, a malicious webpage tricks users by changing its content to resemble a familiar site, such as a bank login page, capturing their credentials when they switch back to the tab. Reverse tabnabbing involves a seemingly legitimate website that deceives users into opening a malicious link, which then alters the content of the original tab to a phishing site.

Analogy: Tabnabbing: you leave a shop for a minute, and when you come back the shop front has been swapped for a fake bank. Reverse tabnabbing: the shop you were in is changed after you open a door from it.

How it works (numbered steps):

Tabnabbing:

1. The victim opens a malicious page in a browser tab and then switches to another tab.
2. The script on the page detects that the tab is idle.
3. The page changes its title, icon (favicon), and content to look like a login page.
4. The victim returns to the tab, thinks he was logged out, and types credentials.

Reverse tabnabbing:

1. A legitimate page contains a link that opens a new tab.
2. The new page can change the original tab using the opener reference (ADDED CONTEXT: the window.opener property).
3. The original tab is changed to a phishing page.
4. The victim returns to the original tab and enters credentials.

Real-world use: A forum post contains an external link. The linked page silently rewrites the forum tab into a login screen. Many users re-enter their forum password.

Tools and commands used here: None named on the slide. ADDED CONTEXT: the HTML attribute rel="noopener noreferrer" prevents the opener link; security tests check for it.

AI angle: Not specific. AI can generate polished fake login pages that match the real design.

Countermeasures and defense: Developers add rel="noopener noreferrer" to external links. Users should check the address bar and the tab icon before typing, close unused tabs, use a password manager (it will not fill a fake domain), and use two-factor authentication.

EXAM FOCUS: Keywords: "switch back to the tab", "changes its content", "resemble a familiar site". Trap: tabnabbing alters an idle tab; reverse tabnabbing alters the original tab from a newly opened one.

Memory trick: "Tab + nab = grab the tab while you look away."

Consent Phishing

What it is (simple words): An attacker exploits the OAuth authentication protocol used by web services by developing a fake, legitimate-looking application or website, then lures the victim into visiting it through various means. OAuth is the standard that lets an app act for you ("Sign in with Google") without ever seeing your password.

Analogy: You do not give a thief your house key. You sign a paper that says "this person may enter any time". The paper looks real, and the door lets him in.

How it works (numbered steps):

1. The attacker registers an app with a trusted-looking name (for example "Document Viewer").
2. He sends the victim a link that opens the real login page of a big provider and shows a consent screen.
3. The screen asks for broad permissions (read mail, read files).
4. The victim clicks Allow.
5. The app receives an access token and reads the data. No password is stolen, and two-factor authentication does not stop it.

```
victim -> opens link -> real provider consent screen (fake app)
victim clicks Allow  -> attacker app receives a token
attacker uses token  -> reads mail and files (no password needed)
```

Real-world use: A user receives an email "Shared file: Budget 2026". Clicking opens a permission screen. She allows it. The attacker reads her inbox for weeks. The admin finds the unknown app in the list of authorised apps.

Tools and commands used here: None named. ADDED CONTEXT: identity admin consoles list authorised apps and let admins revoke them.

AI angle: AI can write convincing app names and descriptions and generate privacy-policy text to look legitimate.

Countermeasures and defense: Restrict who can approve apps (admin consent workflow). Review requested permissions. Revoke unknown apps. Train users to read the consent screen. Monitor for new app registrations.

EXAM FOCUS: Keywords: "OAuth", "fake application", "permissions", "consent". Trap: the password is never stolen, so password changes alone do not remove the access. Revoke the app token.

Memory trick: "Consent = you say Yes, the attacker says Thanks."

Search Engine Phishing

What it is (simple words): An attacker manipulates search engine results, leading users to visit fraudulent websites crafted to steal sensitive information or distribute malware.

Analogy: A fake signpost put at the top of the road map, so everybody follows it.

How it works (numbered steps):

1. The attacker builds a fake site (shop, bank, software download).
2. He raises its rank with search engine optimization (SEO) tricks or buys ads.
3. A user searches for a product or a login page.
4. The fake site appears near the top.
5. The user trusts the ranking and enters data or downloads a file.

Real-world use: An office worker searches for a "free PDF editor" and clicks the first ad. The download is a trojan. The company blocks newly registered domains afterwards.

Tools and commands used here: SEO manipulation and malicious ads (concept).

AI angle: AI can create thousands of keyword-rich fake pages and reviews quickly (ADDED CONTEXT).

Countermeasures and defense: Type known addresses directly or use bookmarks. Download only from the vendor site. Treat sponsored results with care. Use DNS and web filtering with domain reputation.

EXAM FOCUS: Keywords: "manipulates search engine results", "fraudulent websites". Trap: no email is involved.

Memory trick: "Search engine phishing = Search, click, caught."

3.20 Phishing Tools [page 6, slide 17]

What it is (simple words): The slide shows two main tools and a list of other tools. Pen testers use them to run authorized phishing exercises. Attackers misuse the same tools. Use them only with written permission.

The Social-Engineer Toolkit (SET)

What it is: SET is an open-source, Python-driven tool aimed at penetration testing around social engineering. It is a product of TrustedSec (website shown: trustedsec.com). The start

screen says it is easy to update through the Penetration Testers Framework (PTF). The screenshot title bar shows it running in a Parrot terminal as `setoolkit`.

Main menu (as shown):

No.	Menu entry
1	Social-Engineering Attacks
2	Penetration Testing (Fast-Track)
3	Third Party Modules
4	Update the Social-Engineer Toolkit
5	Update SET configuration
6	Help, Credits, and About
99	Exit the Social-Engineer Toolkit

On the slide, option 1 (Social-Engineering Attacks) is boxed, and option 2 (Website Attack Vectors) is boxed in the next menu.

Social-Engineering Attacks menu (as shown):

No.	Attack vector
1	Spear-Phishing Attack Vectors
2	Website Attack Vectors
3	Infectious Media Generator
4	Create a Payload and Listener
5	Mass Mailer Attack
6	Arduino-Based Attack Vector
7	Wireless Access Point Attack Vector
8	QRCode Generator Attack Vector
9	Powershell Attack Vectors
10	Third Party Modules
99	Return back to the main menu

What each vector means in simple words:

- **Spear-Phishing Attack Vectors:** send crafted emails with a malicious file to chosen people.
- **Website Attack Vectors:** host fake or cloned web pages that capture credentials or serve a payload (credential harvester, tabnabbing, and so on, ADDED CONTEXT).
- **Infectious Media Generator:** build a USB, CD, or DVD that runs a payload (links to baiting).

- **Create a Payload and Listener:** make a payload and start the receiver that waits for the callback.
- **Mass Mailer Attack:** send an email to many addresses.
- **Arduino-Based Attack Vector:** program an Arduino-type board that acts like a keyboard.
- **Wireless Access Point Attack Vector:** run a fake access point (rogue AP).
- **QRCode Generator Attack Vector:** create a QR code that points to a chosen URL.
- **Powershell Attack Vectors:** generate PowerShell-based payloads.

Analogy: SET is a workshop with many ready-made props for staged tricks. A trained actor (the tester) picks the prop.

How it works (numbered steps, defender-friendly view):

1. The tester starts SET and chooses 1) Social-Engineering Attacks.
2. He chooses a vector (for example 2) Website Attack Vectors).
3. He picks a method and a template or a site to clone.
4. He sends the link to the consenting test group.
5. SET records who submitted data. The tester reports the results.

Real-world use: A company asks a security firm for a phishing awareness test. The firm uses SET on a lab server, clones the intranet login in a test environment, and reports which departments entered data.

ShellPhish

What it is: ShellPhish is a phishing tool used to phish user credentials from various social networking platforms such as Instagram, Facebook, Twitter, LinkedIn, and others. The window title in the screenshot reads `bash shellphish.sh` in a Parrot terminal. [UNCLEAR on page 6: the exact script name]

Menu (from the screenshot, partly readable): a numbered list of platforms such as Facebook, Instagram, Google, Microsoft, Netflix, PayPal, Steam, Twitter, PlayStation, GitHub, Twitch, Pinterest, Snapchat, LinkedIn, eBay, Dropbox, ProtonMail, Spotify, Reddit, Adobe, DeviantArt, and more [UNCLEAR on page 6: exact numbers and the last entries], followed by a prompt "Choose an option".

What the output lines show (Instagram example):

Line on screen	Meaning
Initializing ... (localhost:xxxx)	Local web server is starting (port [UNCLEAR])
Successfully hosted at: http://localhost:xxxx	The fake page is live on the local machine
Waiting for Login Info, Press Ctrl + C to exit	Tool waits for a victim to submit data
Victim IP Found!	A visitor opened the page
Saved: sites/instagram/victim_ip.txt	IP address stored in a file

Line on screen	Meaning
Login Info Found!	Visitor submitted a form
Account / Password (hidden in the screenshot)	The captured user name and password
Saved: sites/instagram/login_info.txt	Credentials stored in a file

The red boxes on the slide mark the saved files and the captured account and password. The port number is small [UNCLEAR on page 6], so the table uses xxxx.

Analogy: ShellPhish is a vending machine for fake login pages. Pick a brand and the machine serves a copy.

Real-world use: In an authorized lab, a trainer shows how a fake Instagram page captures a password so that staff can see how little a victim notices. The trainer then shows the signs: wrong address, no real certificate, and an unexpected login prompt. The tool is used only against test accounts.

Other Phishing Tools (listed on the slide)

Tool	What it is (simple)	Source shown
Dark-Phish	Phishing page toolkit for social sites	github.com
BLACKEYE	Phishing page generator with many site templates	github.com
SocialFish	Educational phishing tool for credential pages	github.com
Modlishka	Reverse proxy that relays a real login page	github.com
Trape	Tracks victims and harvests data (OSINT and phishing)	github.com
Gophish	Open-source phishing simulation framework	getgophish.com
King Phisher	Tool for phishing campaign simulation	github.com

> **ADDED CONTEXT:** Short descriptions of the tools above are general knowledge; verify current details before the exam. Modlishka is notable because it acts as a reverse proxy: it passes traffic to the real site, so it can capture session cookies and often bypass two-factor codes. That is why hardware security keys and phishing-resistant authentication are recommended.

Tools and commands used here: `setoolkit`, `bash shellphish.sh` (see section 5).

AI angle: Attackers may use AI to write phishing templates and to clone the look of a site. Defenders use AI-based email security, and testers use AI to draft campaign text for

authorized simulations. Example prompt (tester): "Draft a harmless phishing-awareness email for a simulated campaign that tells staff to report it using the Report Phishing button."

Countermeasures and defense: The tools above only work if a user believes the page. Defenses: training, spam filters, domain reputation filtering, DNS filtering, certificate and address checks, password managers (they do not fill on the wrong domain), and phishing-resistant multi-factor authentication (FIDO2 security keys, ADDED CONTEXT).

EXAM FOCUS:

- Keywords: "open-source Python-driven tool", "penetration testing around social engineering" -> SET. "phish user credentials from social networking platforms such as Instagram, Facebook, Twitter, LinkedIn" -> ShellPhish.
- Common trap: SET is made by TrustedSec. It has an interactive numbered menu. It is not a vulnerability scanner.
- Look-alike: SET vs Gophish. SET is a toolkit of many vectors, Gophish is a campaign framework with a dashboard and tracking. OhPhish (3.32) is a commercial awareness platform.

Memory trick: "SET = Social-Engineer Toolkit, Python, TrustedSec." For the "other tools" list: "D-B-S-M-T-G-K": Dark-Phish, BLACKEYE, SocialFish, Modlishka, Trape, Gophish, King Phisher.

3.21 Other Techniques for Computer-based Social Engineering [page 6, slide 19]

The slide lists six techniques. Each is short, so they share one section.

Pop-up Windows

What it is (simple words): Windows that suddenly pop up while surfing the Internet and ask for user information to login or sign-in.

Analogy: A stranger steps in front of you on the street and says "Your card has expired. Show it to me."

How it works (numbered steps):

1. The user visits a site or clicks an ad.
2. A window appears that looks like a system alert or a session-timeout notice.
3. It asks for a user name, password, or card number.
4. The data goes to the attacker.

Real-world use: A pop-up says "Session expired. Sign in again." on an unrelated page. A user types a mail password. The attacker reads the mailbox.

Tools and commands used here: Browser pop-up blockers, ad blockers.

Countermeasures and defense: Pop-up blocker on, never type credentials into a pop-up, close the whole browser if unsure, and keep browsers updated.

EXAM FOCUS: Keyword: "suddenly pop up", "ask for user information". Trap: a pop-up that downloads software is scareware (below); a pop-up that asks for sign-in is pop-up phishing.

Memory trick: "Pop-up = Please login now."

Hoax Letters

What it is (simple words): Emails that issue warnings to the user about new viruses, Trojans, or worms that may harm the user's system. The warning is false, but the email asks people to act (delete a file, forward the message, or install a "fix").

Analogy: A false fire alarm that makes everyone run out, while a thief walks in.

How it works (numbered steps):

1. The attacker writes a scary warning about a "new virus".
2. It tells the reader to delete a system file or to install a tool, and to forward the warning.
3. Users panic, harm their own PCs, or install malware. The message spreads and wastes time.

Real-world use: An email says "Delete the file jdbgmgr.exe now, it is a virus". Users delete a real file. The result: damage to their own systems (this is a classic historical hoax, ADDED CONTEXT).

Tools and commands used here: None. Fact-checking sites and the vendor's own advisories are the checks.

Countermeasures and defense: Do not forward warnings. Verify with IT or the vendor. Follow a policy: "report, do not forward".

EXAM FOCUS: Keywords: "warnings about new viruses, Trojans, or worms". Trap: hoax letters give false warnings. Chain letters offer free gifts.

Memory trick: "Hoax = Horror story."

Chain Letters

What it is (simple words): Emails that offer free gifts such as money and software on condition that the user forwards the mail to a specified number of people.

Analogy: A "pass it on" rumor with a prize at the end. The only winner is the sender.

How it works (numbered steps):

1. The email promises a reward if the reader forwards it to a set number of people (for example 10).

2. Each recipient forwards it.
3. The attacker harvests the list of addresses, or the message carries tracking or malware.
4. The attacker uses the verified addresses for spam and phishing.

Real-world use: A "free software license" mail asks everyone to send it to 20 friends. Months later, the spread addresses are used for a phishing campaign.

Tools and commands used here: None.

Countermeasures and defense: Do not forward chain mail. Spam filters. Policy against mass forwarding.

EXAM FOCUS: Keywords: "free gifts", "forwards the mail to a specified number of people". Trap: Chain letter = reward for forwarding. Hoax letter = false warning.

Memory trick: "Chain = Cash if you pass it on."

Instant Chat Messenger

What it is (simple words): Gathering personal information by chatting with a selected user online to get information such as birth dates and maiden names. These facts are common password reset answers.

Analogy: A friendly pen pal who slowly asks for the answers to your bank's security questions.

How it works (numbered steps):

1. The attacker contacts a user on a chat platform.
2. He builds rapport through friendly talk.
3. He asks small questions (birthday, school, pet, mother's maiden name).
4. He uses the answers to reset accounts or guess passwords.

Real-world use: A "new colleague" on a chat app asks everyone's birth month "for a team calendar". The attacker uses the data to guess passwords and answer reset questions.

Tools and commands used here: Chat clients. Related: spimming (3.18).

AI angle: AI chatbots can hold long, friendly conversations and slowly collect personal facts at scale.

Countermeasures and defense: Never share personal identifiers in chat. Treat security questions as passwords: use false answers stored in a password manager.

EXAM FOCUS: Keywords: "birth dates and maiden names", "chatting". Trap: do not pick spimming (spam), the goal here is personal facts.

Memory trick: "Chat = Collect answers (security questions)."

Spam Email

What it is (simple words): Irrelevant, unwanted, and unsolicited emails that attempt to collect financial information, social security numbers, and network information.

Analogy: Junk mail that sometimes contains a trap, such as a form asking for your account number.

How it works (numbered steps):

1. The sender mails a huge list of addresses.
2. Messages contain lures, links, or attachments.
3. A small percentage of users respond.
4. The attacker collects data or infects devices.

Real-world use: A "tax refund" spam collects social security numbers on a fake form. The result is identity theft (3.24).

Tools and commands used here: Spam filters, email gateways.

Countermeasures and defense: Spam filters, block lists, do not reply or click "unsubscribe" on unknown mail, and report it.

EXAM FOCUS: Keywords: "irrelevant, unwanted, unsolicited". Trap: Spam is not always an attack by itself; here it is a vehicle that collects data.

Memory trick: "Spam = Sent to many, sensitive data wanted."

Scareware

What it is (simple words): Malware that tricks computer users into visiting malware-infested websites, or downloading or buying potentially malicious software. It uses fear (a fake virus alert) to push a quick action.

Analogy: A salesman who breaks your window and then sells you a "protection service".

How it works (numbered steps):

1. A pop-up or page says "Your PC is infected with 37 viruses".
2. It shows a fake scan with red alerts.
3. It offers a "cleaner" to download or buy.
4. The "cleaner" is malware or a payment scam.

Real-world use: A user sees a full-screen alert with a phone number "Call Microsoft support". The call leads to a fake technician (vishing) who asks for remote access.

Tools and commands used here: Real antivirus tools to check; browser close or task manager to stop the page.

Countermeasures and defense: Use only trusted antivirus. Close the tab, do not call numbers in pop-ups. Block malicious ads and keep systems updated.

EXAM FOCUS: Keywords: "tricks users into visiting malware-infested websites", "downloading/buying". Trap: it is fear driven (intimidation or urgency).

Memory trick: "Scareware = Scared into Spending."

3.22 Deepfake Videos, Voice Cloning and AI-based Impersonation [page 2, slide 5; page 12, slide 36]

> **ADDED CONTEXT:** Slide 5 lists "Create Deepfake Videos" and "Voice Cloning" under computer-based techniques. The summary slide (page 12) says the module covers "Impersonation using AI". Your screenshots have no detail slide for these (printed slides 20 and 21 are not included). The text below is added knowledge so you can answer exam questions.

What it is (simple words):

- **Deepfake:** a fake video, image, or audio made by AI (deep learning) to show a real person saying or doing something they never did.
- **Voice cloning:** an AI model copies a person's voice from a short recording and then speaks any text in that voice.
- **AI impersonation:** the use of these tools to pretend to be a boss, colleague, family member, or official.

Analogy: A master impersonator who never gets tired and can copy anybody from a short sample.

How it works (numbered steps):

1. The attacker collects audio or video of the target (interviews, social media, webinars).
2. A voice or face model is trained or prompted with the sample.
3. The attacker generates a fake call, voice note, or video (even live on a video call).
4. The fake is used in a normal scam: urgent payment, password reset, or sharing a secret.
5. The victim trusts the familiar face or voice.

Real-world use: A finance clerk joins a video call where the "CFO" and "colleagues" ask for an urgent transfer. All faces are deepfakes. The money is sent. Public cases of this kind have been reported (verify details before quoting).

Tools and commands used here: Face-swap and voice-synthesis tools exist as open-source projects and commercial services. Exact tool names vary by course version, so verify names before the exam. Defensive tools include deepfake-detection services and content-provenance standards such as C2PA (ADDED CONTEXT, verify).

AI angle: This whole topic is the AI angle. Attacker view: scale, low cost, language support. Defender view: detection models, liveness checks (ask the caller to turn their head or say a random phrase), and secret code words. Example prompt (defender): "Create a one-page policy for verifying urgent payment requests received by phone or video call."

Countermeasures and defense:

1. Verify urgent or unusual requests through a second channel and a known number.
2. Use a pre-agreed code word for money or access requests.
3. Require dual approval for payments.
4. Look for signs: unnatural blinking, lip-sync errors, odd lighting, robotic breathing.
5. Train staff with simulated deepfake calls.
6. Limit public audio and video of executives where possible.

EXAM FOCUS:

- Keywords: "AI-generated", "synthetic media", "cloned voice", "CEO fraud".
- Common trap: Seeing and hearing is no longer proof. The best defense is process (callback and dual approval), not trusting your eyes.
- Look-alike: Deepfake (media) vs Voice cloning (audio only) vs Vishing (the phone call that may use the clone).

Memory trick: "Deep = Deep learning. Fake = Face. Clone = Copy the voice."

3.23 Perform Impersonation on Social Networking Sites [page 7, slide 22]

What it is (simple words): Malicious users gather confidential information from social networking sites and create accounts using another person's name. They use these fraudulent profiles to create large networks of friends and extract information using social engineering techniques.

Details gathered (left side of the slide): Organization details, professional details, contacts and connections, and personal details. The slide shows logos of Facebook, LinkedIn, MySpace, Twitter, and Google+ as sources. [UNCLEAR on page 7: MySpace and Google+ icons are small; they are old networks]

Analogy: A forged business card with your name on it, handed to your friends.

How it works (numbered steps):

1. The attacker collects public facts about a target and the target's contacts.
2. He creates a fake account with the target's name and photo.
3. He sends friend requests to the target's contacts, who accept because the name is familiar.
4. He chats and asks for information or sends malicious links.

Real-world use: A fake "HR manager" profile friends many staff of a company on a professional network. It then asks for "a quick survey" with a link to a malware page.

Angler Phishing

What it is: Attackers create a fake social media account impersonating an organization's helpdesk account and connect to disgruntled customers by posting fake service links. When victims click on the link, malicious software gets installed on their system, or they are redirected to another site requesting them to provide their details.

Analogy: An angler fish hangs a glowing lure in the dark. Upset customers swim toward the "support" light.

How it works (numbered steps):

1. A customer posts a complaint about a company on social media.
2. The attacker watches for complaints and replies from a fake support account.
3. The reply has a link "to resolve your issue".
4. The customer clicks and enters data or gets infected.

Real-world use: A bank customer tweets about a failed transfer. A fake "BankHelp" account replies with a link. The customer enters card details.

Catfishing Attack

What it is: Attackers target a person on social media platforms and perform identity theft to create a fake social media account. Then, the attackers use the fake account for communicating with other users via chat boxes to perform cyberbullying for monetary gain.

Analogy: A mask. The real face is hidden, and the mask is built from a real person's identity.

How it works (numbered steps):

1. The attacker steals photos and facts of a real person.
2. He opens a fake profile in that name.
3. He starts chats with other users, builds emotional trust.
4. He asks for money, intimate content, or personal data, or uses threats (cyberbullying) for money.

Real-world use: A person finds that her photos are used on a fake profile that asks other users for "emergency money".

Tools and commands used here: Social networking sites. Defensive: reverse image search (Google Lens, TinEye, ADDED CONTEXT).

AI angle: AI-made profile photos and AI-written chat allow fake accounts at scale. Example prompt (defender): "List red flags in a social media profile that suggest it is fake."

Countermeasures and defense: Limit public details on profiles. Accept only people you know. Report fake accounts at once. Verify profile pictures with a reverse image search. Companies should publish their official support handles and monitor for look-alike accounts.

EXAM FOCUS:

- Keywords: "fake social media account impersonating an organization's helpdesk", "disgruntled customers", "fake service links" -> Angler phishing. "identity theft", "cyberbullying for monetary gain" -> Catfishing.
- Common trap: Angler phishing is about customer-service accounts; catfishing is about a fake personal identity.
- Look-alike: Honey trap (3.12) targets a company insider for corporate secrets.

Memory trick: "Angler = Aid desk fake. Cat = Costume of a person."

3.24 Identity Theft [page 7, slide 23]

What it is (simple words): Identity theft is a crime in which an imposter steals personally identifiable information (PII) such as name, credit card number, social security or driver's license numbers, and uses it to commit fraud or other crimes. Attackers can also use identity theft to impersonate employees of a target organization and physically access facilities.

Analogy: Someone copies your signature and spends your money. The bank thinks it is you.

How it works (numbered steps):

1. The attacker gathers PII from trash, phishing, data breaches, or social media.
2. He combines the facts into a usable identity.
3. He opens accounts, takes loans, files taxes, or enters buildings as that person.
4. The victim finds out much later.

Indications of identity theft (slide list):

1. Unfamiliar charges to your credit card that you do not recognize.
2. No longer receiving credit card, bank, or utility statements.
3. Getting calls from the debit or credit fraud control department.
4. Charges for medical treatment or services you never received.
5. No longer receiving electricity, gas, water, etc. service bills.

Real-world use: A man stops getting bank statements. The attacker changed his mailing address. He later sees loans in his name. He freezes credit and reports to police.

Tools and commands used here: None. Credit report checks and credit freeze services.

AI angle: AI can create fake documents and synthetic identities (mixing real and invented data). Voice cloning can defeat phone-based identity checks. Defenders use AI fraud scoring.

Countermeasures and defense: See 3.30.

EXAM FOCUS:

- Keywords: "personally identifiable information", "imposter", "driver's license", "physically access facilities".
- Common trap: Identity theft is the crime; phishing and dumpster diving are methods to get the data.
- Look-alike: Identity theft vs Impersonation. Impersonation is acting as someone else in one conversation. Identity theft is stealing the data to use that person's identity for fraud.

Memory trick: "PII = Person's Identity Items." Signs: "Stops, Strange, Surprise, Statements".

3.25 Publishing Malicious Apps and Repackaging Legitimate Apps [page 8, slide 25]

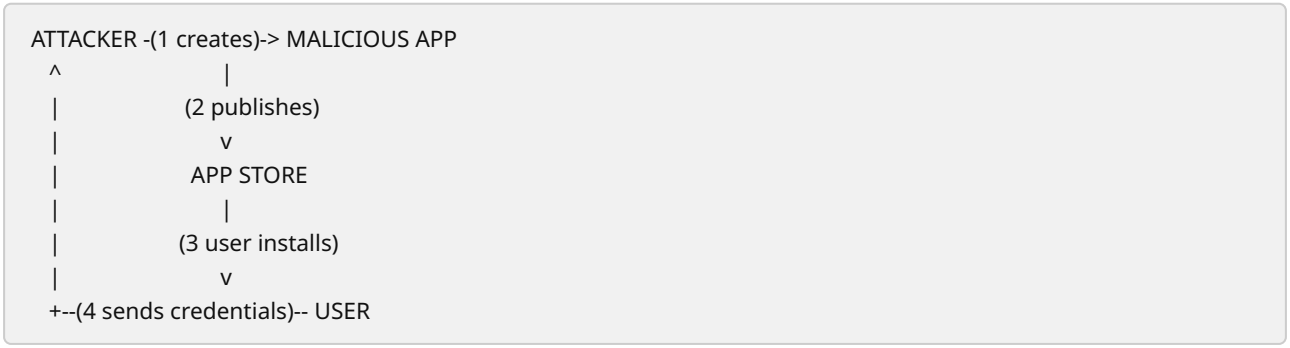
What it is (simple words): Two mobile attacks shown side by side on one slide.

Publishing Malicious Apps

What the slide says: Attackers create malicious apps with attractive features and similar names to popular apps, and publish them in major app stores. Users download these apps unknowingly and are infected by malware that sends credentials to attackers.

Steps (from the diagram):

1. The attacker creates a malicious mobile application (the diagram shows a "malicious gaming application").
2. The attacker publishes malicious mobile apps on the app store.
3. The user downloads and installs the malicious mobile application.
4. The app sends user credentials to the attacker.

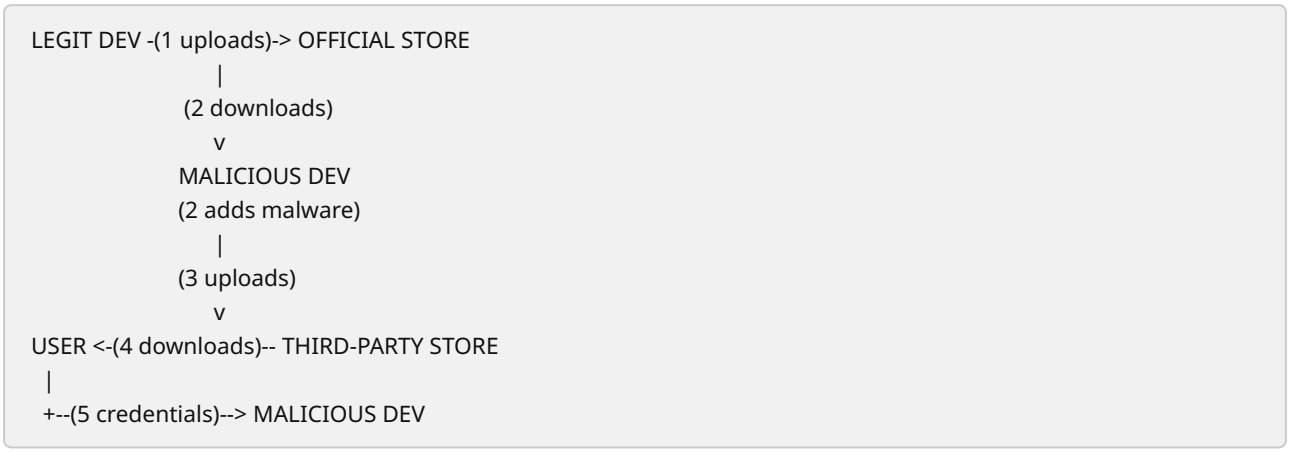


Repackaging Legitimate Apps

What the slide says (diagram steps):

1. A legitimate developer creates a gaming app and uploads it on the (official) mobile app store.
2. A malicious developer downloads a legitimate game and repackages it with malware.
3. The malicious developer uploads the game to a third-party app store.

4. The end user downloads the malicious gaming app from the third-party store.
5. The app sends user credentials to the malicious developer.



Analogy: Publishing a malicious app is printing a fake brand of cereal. Repackaging is opening a real box of cereal, adding poison, and gluing it shut again.

Real-world use: A tester shows how a popular game, once repackaged and uploaded to an unofficial store, still looks the same but adds a hidden data-stealing part. The company bans sideloading on company phones.

Tools and commands used here: None named on the slide. ADDED CONTEXT: apktool (decompile and rebuild Android APK files) is a typical repackaging tool; verify.

AI angle: AI can write app descriptions and reviews to look real, and can help produce code variations that evade scanners.

Countermeasures and defense: Install only from official stores, check the developer name and reviews, review requested permissions, keep Play Protect or equivalent on, use mobile device management (MDM), block sideloading, and keep the OS patched.

EXAM FOCUS:

- Keywords: "similar names to popular apps" -> publishing malicious apps. "downloads a legitimate game and repackages it with malware", "third-party app store" -> repackaging.
- Common trap: Repackaging starts from a real app; the other creates a new fake app.
- Look-alike: Fake security apps (3.26) pretend to be security tools.

Memory trick: "Publish = Produce new fake. Repackage = Reuse real."

3.26 Fake Security Applications and SMiShing (SMS Phishing) [page 8, slide 26]

Fake Security Applications

What it is (simple words): An attacker tricks a user into installing a "security" app on the phone, but the app is malware that steals credentials. The diagram shows a user who logs on

to a bank account on a PC and sees a message telling them to download an application to their phone.

Steps (from the diagram, order partly unclear [UNCLEAR on page 8]):

1. The attacker infects the user PC with malware.
2. The user logs on to the bank account on the PC. A message appears telling the user to download an application to their phone. (This message is injected by the malware.)
3. The attacker uploads the malicious application on an app store (the attacker's app store).
4. The user downloads the application from the attacker's app store.
5. The user credentials are sent to the attacker.

Analogy: A "bank security guard" appears at your door with a free lock. The lock sends a copy of your key to the thief.

Real-world use: A banking trojan on a PC injects a page that says "Install our security app for safe banking". The app reads one-time codes from SMS and sends them to the attacker. (This is a documented pattern, ADDED CONTEXT, verify names.)

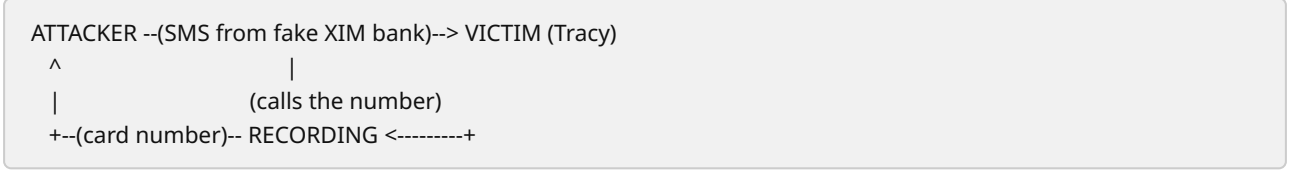
SMiShing (SMS Phishing)

What it is (simple words): SMiShing is the act of using the SMS text messaging system of cellular phones or other mobile devices to lure users into instant action, such as downloading malware, visiting a malicious webpage, or calling a fraudulent phone number.

Slide example: The attacker sends an SMS. Tracy thinks it is a real message from "XIM bank". The text says to call a phone number [UNCLEAR on page 8: number]. A recording asks her to provide her credit or debit card number. Tracy reveals sensitive information.

How it works (numbered steps):

1. The attacker sends a text that looks like a bank notice.
2. It creates urgency ("Your account is blocked, call now").
3. The victim calls the number or clicks the link.
4. A recorded voice or fake page asks for card or login data.
5. The victim reveals the data.



Analogy: A forged bank letter, but delivered to your pocket by text.

Real-world use: A parcel text says "Your delivery failed. Pay a small fee here". The link is a card-stealing page.

Tools and commands used here: None on the slide. ADDED CONTEXT: SET and other kits can support SMS-style lures; bulk SMS gateways and SMS spoofing sites are common attacker tools.

AI angle: AI writes natural local-language texts and adjusts them per target. Defenders use AI-based message filters on carriers and phones.

Countermeasures and defense: Never click links in unexpected texts. Do not call numbers from the message. Contact the bank using its official app or number. Block and report the sender. Banks should state that they never ask for card details by SMS or recorded call.

EXAM FOCUS:

- Keywords: "SMS text messaging", "lure users into instant action" -> SMiShing. "installs a security app on a phone" -> fake security app.
- Common trap: SMiShing is mobile-based even though phishing is computer-based.
- Look-alike: SMiShing vs Vishing. SMiShing starts with text; vishing is a voice call. In the slide example, the final step is a recorded call (a vishing step), but the type is SMiShing because the lure was an SMS.

Memory trick: "SMiShing = SMS + phishing." The small i and sh come from SMS and phishing.

3.27 QRLJacking [page 9, slide 27]

What it is (simple words): QRLJacking is a type of social engineering attack that exploits the QR Code Login method in various web applications to hijack login sessions and gain unauthorized access to victims' accounts. QRL stands for Quick Response code Login.

Analogy: A web app shows a QR code as a one-time key card for login. The attacker photographs the card at the door of the real building, then places a copy in a place where the victim will scan it. The victim's phone approves the attacker's session.

How it works (numbered steps from the slide diagram):

1. The attacker initiates a QR code login session with the web service. (The step number on the slide is cut off [UNCLEAR on page 9], most likely 01.)
2. The web service returns the QR code.
3. The attacker clones the retrieved QR code.
4. The attacker creates a phishing webpage using the cloned QR code.
5. The attacker sends the phishing webpage URL to the victim.
6. The victim scans the malicious QR code with a phone that is logged in to the service.
7. The victim's device ID and login credentials are sent to the attacker (the service links the attacker's session to the victim's account).
8. The attacker logs in to the victim's account.

```
ATTACKER ---(start QR login)---> WEB SERVICE
ATTACKER <---(QR code)---------- WEB SERVICE
ATTACKER clones QR -> builds phishing page -> sends URL to VICTIM
VICTIM scans the QR with a logged-in phone
WEB SERVICE links attacker session to the victim account
ATTACKER logs in as the victim
```

QR TIGER (tool shown on the slide): QR TIGER is a QR code generator tool that allows attackers to create a duplicate copy of a legitimate static or dynamic QR code. The screenshot shows a campaign list with menu items such as Add to watchlist, Move to folder, Clone QR code (highlighted), and Reset QR Code. Source shown: qrcode-tiger.com.

> **ADDED CONTEXT:** A static QR code holds fixed data (cannot be changed later). A dynamic QR code points to a short link that can be changed later, and may track scans. Dynamic codes are easier to abuse because the destination can be swapped after printing. QRLJacking was published by researchers in 2016 and is an OWASP project (verify). Related terms: "quishing" means QR code phishing.

Real-world use: A tester shows that a chat web app's "scan to log in" QR code can be relayed to a victim through a fake page. The victim scans it and the tester's browser logs in as the victim. The fix: ask for confirmation of device and location on the phone.

Tools and commands used here: QR TIGER (QR code generator). ADDED CONTEXT: QRLJacker (an OWASP tool) is a framework made to demonstrate the attack; verify before the exam.

AI angle: AI can create look-alike pages and persuasive messages that pull victims to the QR page. Defenders use AI tools that scan QR code destinations before opening.

Countermeasures and defense: Do not scan QR codes from unknown sources. Check the URL a QR code opens before tapping. Prefer apps that ask for approval with device and location details. Use short session times, notify the user of new logins, review "linked devices" regularly and log out unknown ones, and use phishing-resistant multi-factor authentication.

EXAM FOCUS:

- Keywords: "QR Code Login method", "hijack login sessions", "duplicate copy of a legitimate static or dynamic QR code" -> QRLJacking and QR TIGER.
- Common trap: QRLJacking targets "login with QR code", not a normal QR code that opens a link. It is a session hijack.
- Look-alike: QRLJacking vs Quishing. Quishing is phishing through a QR code that points to a fake site. QRLJacking hijacks a QR-based login session.

Memory trick: "QRL = QR Login. Jack = steal the session."

3.28 Social Engineering Countermeasures [page 9, slide 29; page 10, slide 30]

What it is (simple words): The slides say good policies and procedures are ineffective if they are not taught to and reinforced by employees. After receiving training, employees should sign a statement acknowledging that they understand the policies. The main objectives of social engineering defense strategies are to create user awareness, robust internal network controls, and secure policies, plans, and processes.

Analogy: A fire drill. A rule on paper does not save anyone. A practiced habit does.

How it works (numbered steps):

1. Write clear policies (what may be shared, with whom, and how identity is checked).
2. Train every employee, and test them.
3. Make employees sign that they understand the policies.
4. Add technical and physical controls that back up the policy.
5. Measure, find gaps, fix them, and repeat.

```
AWARENESS ------+
NETWORK CONTROLS +--> DEFENSE AGAINST SOCIAL ENGINEERING
POLICIES AND PLANS +
```

Password Policies (slide 29)

Policy	Simple meaning
Periodic password changes	Change passwords on a schedule
Avoiding guessable passwords	No names, dates, or "Password1"
Account blocking after failed attempts	Lock the account after repeated wrong tries
Increasing length and complexity	Longer passwords with mixed characters
Improving secrecy of passwords	Never share or write passwords where others see

> **ADDED CONTEXT:** Current guidance (for example NIST SP 800-63B, verify) favors length and a banned-password list over forced frequent changes. For the exam, use the slide list.

Physical Security Policies (slide 29)

Policy	Simple meaning
Identification of employees	Issue ID cards, uniforms, and similar
Escorting visitors	A staff member stays with each visitor
Restricting access to work areas	Only authorized people enter
Proper shredding of useless documents	Stops dumpster diving

Policy	Simple meaning
Employing security personnel	Guards and reception control

Defense Strategy (slide 29)

- **Social engineering campaign:** run a planned test, such as a simulated phishing or vishing campaign, to see how staff react.
- **Gap analysis:** compare the current state (what staff did) with the target state (what the policy wants). The difference is the gap.
- **Remediation strategies:** actions to close the gaps: more training, new policy, new controls.

The 10 countermeasures (slide 30)

1. Train individuals on security policies.
2. Implement proper access privileges.
3. Presence of proper incidence response time (a fast incident response).
4. Availability of resources only to authorized users.
5. Scrutinize information (check requests and data before acting).
6. Background check and proper termination process.
7. Anti-virus and anti-phishing defenses.
8. Implement two-factor authentication.
9. Adopt documented change management.
10. Ensure software is regularly updated.

Real-world use: A company finds in a test that 30 percent of staff opened a fake invoice. It adds a monthly training, a "report phishing" button, and two-factor authentication. The next test drops to 8 percent. The change is measurable.

Tools and commands used here: OhPhish, Gophish (campaigns); Netcraft and PhishTank (3.31); email security gateways; MDM; badge systems.

AI angle: Defenders use AI for adaptive training (personalized content), message classification, and anomaly detection (a manager suddenly asks for gift cards). Example prompt: "Write a 10-point checklist for a help desk agent who receives a password reset request by phone."

EXAM FOCUS:

- Keywords: "sign a statement", "user awareness", "gap analysis", "remediation", "background check", "termination process".
- Common trap: "Best countermeasure" answers usually combine training and policy. A single technical control is rarely the best answer.
- Common trap: Two-factor authentication helps against stolen passwords but does not stop consent phishing or session hijack (QRLJacking).

- Look-alike: Gap analysis (find differences) vs Remediation (fix them) vs Campaign (test staff).

Memory trick: The three objectives: "A-N-P": Awareness, Network controls, Policies. Defense strategy: "C-G-R": Campaign, Gap analysis, Remediation.

3.29 How to Defend against Phishing Attacks [page 10, slide 31]

What it is (simple words): A list of eight actions that reduce phishing risk.

1. Educate individuals by conducting phishing campaigns.
2. Enable spam filters that detect emails from suspicious sources.
3. Hover over links to identify whether they point to the correct location.
4. Check emails for generic salutations, spelling, and grammar mistakes.
5. Confirm the sender before providing the information via email.
6. Ensure that employees use HTTPS-protected websites.
7. Verify the profile pictures of a suspicious account by performing a reverse image search.
8. Immediately report social media accounts confirmed to be fake.

Analogy: A seat belt, an airbag, and a speed limit. Several small protections work together.

How it works (reading each step):

- **Phishing campaigns** (step 1): simulated phishing. Staff who click get immediate training.
- **Spam filters** (step 2): remove most mass phishing before it arrives.
- **Hover over links** (step 3): moving the mouse over a link shows the real destination, which may differ from the text. On a phone, press and hold the link.
- **Generic salutations, spelling, and grammar** (step 4): "Dear customer" and mistakes are classic signs. AI-written phishing may have none of these, so do not rely on this alone.
- **Confirm the sender** (step 5): use a second channel and known contact details.
- **HTTPS** (step 6): HTTPS encrypts traffic, but phishing sites can also use HTTPS. A padlock shows encryption, not honesty.
- **Reverse image search** (step 7): upload a profile photo to see where else it appears.
- **Report fake accounts** (step 8): helps platforms remove them and protects others.

Real-world use: An employee receives "Your parcel is held". She hovers over the link, sees an unknown domain, does not click, and forwards the mail to the security team. Result: the domain is blocked company-wide within the hour.

Tools and commands used here: Email security gateway, reverse image search (Google Lens or TinEye, ADDED CONTEXT), Netcraft extension, PhishTank lookups. For command-line link checking see section 5 (`curl -I`, `nslookup`).

AI angle: AI makes steps 4 and 7 weaker (perfect grammar, AI faces). So rely more on steps 3, 5, and on two-factor authentication.

Countermeasures and defense: The list above is the countermeasure list. ADDED CONTEXT extras: SPF, DKIM, DMARC (email sender checks), disabling macros, attachment sandboxing, and phishing-resistant authentication.

EXAM FOCUS:

- Keywords: "hover", "generic salutations", "reverse image search", "phishing campaigns".
- Common trap: HTTPS does not prove a site is safe.
- Look-alike: Spam filter (blocks mail) vs Anti-phishing toolbar (warns about pages).

Memory trick: "E-S-H-C-C-E-V-R": Educate, Spam filter, Hover, Check mistakes, Confirm sender, Ensure HTTPS, Verify picture, Report fake. Short version: "Teach, Filter, Hover, Verify, Report".

3.30 Identity Theft Countermeasures [page 11, slide 32]

What it is (simple words): Ten habits that make it harder to steal and use your identity.

1. Secure or shred all documents containing your private information.
2. Ensure your name is not present in marketers' hit lists.
3. Review your credit card statement regularly and store it securely, out of reach of others.
4. Never give any personal information over the phone.
5. Keep your mail secure by emptying the mailbox quickly.
6. Be cautious and verify all requests for personal data.
7. Protect your personal information from being publicized.
8. Do not display or share any account or contact numbers unless mandatory.
9. Monitor online banking activities regularly.
10. Never list any personal identifiers on social media.

Analogy: Locking the doors, closing the curtains, and checking the bank statement each month.

How it works (grouping the list):

- **Paper and mail:** items 1, 3, 5 (shred, secure statements, empty the mailbox).
- **What you share:** items 4, 6, 7, 8, 10 (phone, requests, publicity, numbers, social media).
- **Data-broker exposure:** item 2 (marketers' hit lists are lists of people used for marketing).
- **Monitoring:** items 3 and 9 (statements and online banking).

Real-world use: A family moves house and forgets to redirect mail. A thief takes pre-approved credit offers from the old mailbox. Following item 5 would have prevented it.

Tools and commands used here: Paper shredder, credit report services, online banking alerts.

AI angle: Item 10 matters more now. AI can scrape personal details from public profiles and build a profile for a voice-cloning or phishing attack. Example prompt (self-audit): "List the personal details that someone could infer about me from these public posts."

Countermeasures and defense: The list above is the defense. ADDED CONTEXT: credit freeze, fraud alerts, and identity-monitoring services.

EXAM FOCUS:

- Keywords: "shred", "marketers' hit lists", "emptying the mailbox", "personal identifiers on social media".
- Common trap: "Never give personal information over the phone" is absolute in the slide. Choose it over answers that allow phone sharing after "quick verification".

Memory trick: "S-M-R-N-E-B-P-D-M-N" is hard, so group it: "Paper (shred, statements, mail), Phone and people (never give, verify), Public (do not publicize), Pay (monitor banking)".

3.31 Anti-Phishing Toolbar: Netcraft and PhishTank [page 11, slide 34]

Netcraft

What it is (simple words): The Netcraft anti-phishing community is a giant neighborhood watch scheme, empowering the most alert and most expert members to defend everyone within the community against phishing attacks. It offers a browser extension. The screenshot shows a red full-page warning titled "Suspected Phishing" that says the page has been blocked by the Netcraft Extension, shows the blocked URL, and gives options such as "Report mistake" and "Visit anyway" [UNCLEAR on page 11: small buttons]. Source shown: netcraft.com.

Analogy: A neighborhood watch. Many eyes spot the bad house, and everyone is warned.

How it works (numbered steps):

1. Community members and automated systems report suspicious URLs.
2. Netcraft analyses them and adds bad ones to its list.
3. The browser extension checks pages against the list.
4. If a page matches, the extension blocks it and shows a warning.

PhishTank

What it is (simple words): PhishTank is a collaborative clearing house for data and information about phishing on the Internet. It provides an open API (application programming interface) for developers and researchers to integrate anti-phishing data into their apps. The screenshot shows a submission page (Submission #2205890) with the status "Verified: Is a phish" and a note that the submission is currently offline. The screenshot also shows "Error 1015, You are being rate limited" from the website's protection layer; this is a

side effect of the capture and not a PhishTank feature. The page says PhishTank is operated by Cisco Talos Intelligence Group. Source shown: phishtank.com.

Analogy: A public library of known bad addresses. Anyone may look up a book or add a note.

How it works (numbered steps):

1. A user submits a suspicious URL.
2. Other registered users vote whether it is a phish.
3. When enough votes agree, the URL is marked "Verified: Is a phish".
4. Security tools query the list through the API.

Real-world use: A mail security team checks a URL from a reported message in PhishTank. It is a known phish. The team blocks the domain and warns staff.

Tools and commands used here: Browser extension (Netcraft), web lookup and API (PhishTank). ADDED CONTEXT: similar free services include Google Safe Browsing, OpenPhish, and VirusTotal URL scan (verify).

AI angle: Anti-phishing lists can feed AI mail filters. Defenders can ask an AI assistant to summarise a URL report. Do not paste confidential data into public AI tools.

Countermeasures and defense: These two services are themselves countermeasures. Use them with training and filters.

EXAM FOCUS:

- Keywords: "neighborhood watch" -> Netcraft. "collaborative clearing house", "open API" -> PhishTank.
- Common trap: Both are defenses. They are not attack tools.
- Look-alike: Netcraft (browser warning, community) vs PhishTank (database with API, verified by votes) vs OhPhish (employee simulation).

Memory trick: "Net-craft = Neighborhood watch. Phish-Tank = Tank of phish reports."

3.32 Audit Organization's Security for Phishing Attacks using OhPhish [page 12, slide 35]

What it is (simple words): OhPhish is a web-based portal to test employees' susceptibility to social engineering attacks. It is a phishing simulation tool that provides the organization with a platform to launch phishing simulation campaigns on its employees. The logo tagline reads "Fortifying Front Lines". Web address shown: portal.ohphish.com.

Dashboard (as shown):

- Campaign modes (colored buttons): Entice to Click, Credential Harvesting, Send Attachment, Assign New Training, Vishing, Smishing.

- Left menu: Home, User Management, Campaigns, Reports, Awareness Program, Templates, Settings.
- A "Live Phishing Campaigns" table with columns such as Campaign, Campaign Type, Status, Assigned Training, Started, Stopped, Scheduled, Sent, Clicked, Compliance, Creator, and Action [UNCLEAR on page 12: some column names].
- A hint to watch a short walkthrough and to "Select a campaign mode" to get started.

What each campaign mode tests:

Mode	What it tests
Entice to Click	Do users click a risky link?
Credential Harvesting	Do users type credentials into a fake page?
Send Attachment	Do users open a risky attachment?
Assign New Training	Gives training to those who failed
Vishing	Do users fall for voice calls?
Smishing	Do users fall for SMS lures?

Analogy: A fire drill for email. Nobody is hurt, and you learn who needs training.

How it works (numbered steps):

1. The admin imports employees (User Management).
2. The admin picks a campaign mode and a template.
3. The portal sends the simulated lure.
4. It records who clicked, entered data, or opened an attachment.
5. The Reports page shows results, and staff who failed are given training.

Real-world use: A company runs "Credential Harvesting" against 500 staff. The report shows that finance clicked most. Targeted training follows, and a repeat test measures the improvement.

Tools and commands used here: OhPhish. Compare Gophish and King Phisher (3.20), which are used by testers for similar campaigns.

AI angle: AI can help write realistic but safe templates and personalise training by role. Example prompt: "Write three safe phishing-simulation email templates for a finance team, each with a teaching message shown after a click."

Countermeasures and defense: OhPhish is a defensive audit tool. It supports the "social engineering campaign" step in 3.28.

EXAM FOCUS:

- Keywords: "test employees' susceptibility", "phishing simulation campaigns", "platform".

- Common trap: OhPhish is for defenders to test their own staff. SET and ShellPhish are attacker or tester toolkits.
- Look-alike: OhPhish vs Gophish: OhPhish is a hosted commercial portal. Gophish is open source and self-hosted.

> **ADDED CONTEXT:** OhPhish is an EC-Council product (verify). Seeing it in this module follows the pattern of "audit with a tool at the end of the module".

Memory trick: "OhPhish = Oh, who fell for it?"

3.33 Module Summary [page 12, slide 36]

What it is (simple words): The summary slide lists what the module covered.

1. Social engineering concepts along with various kinds of social engineering attacks.
2. Human-based social engineering techniques.
3. Computer-based social engineering techniques.
4. Mobile-based social engineering techniques.
5. Impersonation using AI and impersonation on social networking sites.
6. Identity theft and the various forms it can take.
7. Details of various countermeasures that can defend an organization against social engineering attacks, phishing attacks, and identity theft.

The slide ends with: in the next module, you will see how attackers, as well as ethical hackers and penetration testers, perform DoS and DDoS attacks (Module 10).

EXAM FOCUS: "Impersonation using AI" is a stated topic of this v13 module. Expect questions on deepfakes and voice cloning (see 3.22).

Memory trick: The summary has the same order as the objectives, plus AI and identity theft.

3.34 Related Topics Not Shown in the Notes (ADDED CONTEXT)

> **ADDED CONTEXT:** Printed slides 3, 6, 8, 12, 14, 18, 20, 21, 24, 28 and 33 are not in your screenshots. They may cover items such as the social engineering attack phases (added in 3.3), vishing (3.16), deepfake and AI impersonation (3.22), and insider threats (below). Treat everything in this section as extra knowledge, not as a copy of your slides.

Insider Threats

What it is (simple words): An insider threat is a person with legitimate access (employee, contractor, partner) who harms the organization, on purpose or by mistake. Social engineering is often used to recruit or trick insiders.

Analogy: A trusted housekeeper with a key. The key is real, so the alarm does not ring.

Types of insiders (common course list, verify):

1. Malicious insider: harms the organization on purpose (revenge, money).
2. Negligent insider: careless, breaks rules by mistake.
3. Compromised insider: an outsider has taken over the insider's account.
4. Professional insider: a skilled insider who uses the access for fraud.
5. Pre-departing insider: steals data before leaving.

Countermeasures and defense: Least privilege, separation of duties, background checks and a proper termination process (this matches item 06 in slide 30), activity monitoring (UEBA, user and entity behavior analytics), and clear reporting channels.

EXAM FOCUS: Keywords: "legitimate access", "disgruntled employee", "termination". Trap: a compromised insider is not malicious; an outsider uses their account.

Memory trick: "M-N-C-P-P": Malicious, Negligent, Compromised, Professional, Pre-departing.

4. Tool Encyclopedia

Tools marked "(notes)" appear in your screenshots. Tools marked "(added)" are close alternatives that the exam often places next to them. Use only with written permission and only in scope.

4.1 Phishing and social engineering toolkits

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
SET (notes)	Menu toolkit for many SE attacks	Python, Linux, open source	Gaining access	"Python-driven", "TrustedSec"
ShellPhish (notes)	Fake login pages for social sites	Bash script, Linux	Gaining access	"phish credentials from Instagram"
Dark-Phish (notes)	Phishing page toolkit	GitHub script	Gaining access	Listed under other tools
BLACKEYE (notes)	Many site templates for phishing	GitHub script	Gaining access	Listed under other tools
SocialFish (notes)	Educational phishing framework	Python, Linux	Gaining access	Listed under other tools
Modlishka (notes)	Reverse proxy that relays the real site	Go, open source	Gaining access	"reverse proxy", "bypass 2FA"
Trape (notes)	Tracks and harvests victim data	Python, open source	Gaining access	Listed under other tools
Gophish (notes)	Phishing simulation framework	Go, web dashboard	Gaining access and testing	"open-source phishing framework"
King Phisher (notes)	Phishing campaign tool	Python	Gaining access and testing	Listed under other tools
Zphisher (added)	Fake pages like ShellPhish	Bash script	Gaining access	ShellPhish look-alike
Evilginx (added)	Reverse proxy that steals session cookies	Go	Gaining access	"session cookie", "bypass MFA"
QRLJacker (added)	Demo tool for QRLJacking	Python, OWASP	Gaining access	"QR login session"

4.2 QR, mobile, and AI-related tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
QR TIGER (notes)	Makes and clones static or dynamic QR codes	Web service	Gaining access	"duplicate copy of a QR code"
apktool (added)	Unpacks and rebuilds Android apps	Java, CLI	Gaining access	"repackaging"
Mobile device management (added)	Controls apps on company phones	Enterprise software	Defense	"block sideloading"
ChatGPT (added)	Writes text, scripts, training content	AI chatbot	All phases	"generative AI", prompts
ShellGPT, sgpt (added)	AI assistant inside the terminal	Python CLI	All phases	"AI in the terminal"
WormGPT, FraudGPT (added)	Criminal AI chatbots for scam text	Underground services	Gaining access	"malicious LLM" (verify)
Voice cloning services (added)	Copy a voice from a short sample	Web and open source	Gaining access	"voice cloning"
Deepfake detectors (added)	Spot AI-made faces and voices	Commercial and research	Defense	"detect synthetic media"

4.3 Defense, awareness, and reporting tools

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Netcraft (notes)	Anti-phishing community and browser extension	Browser extension	Defense	"neighborhood watch"
PhishTank (notes)	Community database of phishing URLs with API	Web, open API	Defense	"collaborative clearing house"
OhPhish (notes)	Phishing simulation and awareness portal	Hosted web portal	Defense and audit	"test employees' susceptibility"
Google Safe Browsing (added)	Flags unsafe sites in browsers	Browser service	Defense	"unsafe site warning"
OpenPhish (added)	Feed of phishing URLs	Web feed	Defense	"phishing feed"

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
VirusTotal (added)	Scans files and URLs with many engines	Web service	Defense	"multi-engine scan"
KnowBe4 (added)	Commercial awareness and simulation platform	SaaS	Defense	"security awareness training"
Email gateway with SPF, DKIM, DMARC (added)	Checks the sender and filters spam	Mail security	Defense	"sender authentication"
Reverse image search (added)	Finds where a photo appears online	Web (Google Lens, TinEye)	Defense	"verify profile pictures"

4.4 Reconnaissance helpers for social engineering (added)

Tool	What it does (simple)	Type or platform	Phase used	Exam keyword
Maltego	Links people, emails, and domains in a graph	GUI, OSINT	Reconnaissance	"relationship graph"
theHarvester	Collects emails and names from public sources	Python CLI	Reconnaissance	"email harvesting"
Recon-ng	OSINT framework with modules	Python CLI	Reconnaissance	"modular OSINT"
Social media search tools	Find profiles by name or user name	Web and CLI	Reconnaissance	"profile lookup"

4.5 Look-alike tools and how to pick

If the question says	Think	Not this
Python toolkit for social engineering pen tests	SET	Gophish
Credential pages for Instagram or Facebook	ShellPhish	SET
Open-source phishing campaign dashboard	Gophish	OhPhish
Test employees and give training	OhPhish	ShellPhish

If the question says	Think	Not this
Browser warning from a community	Netcraft	PhishTank
Open API of verified phishing URLs	PhishTank	Netcraft
Clone a QR code	QR TIGER	SET QRCode vector
Reverse proxy that captures sessions	Modlishka or Evilginx	SET

5. Command Sheet

The notes contain no long command lines. They show two tools that you start from a terminal: `setoolkit` and `shellphish.sh`. Both are menu driven, so reading the menu is the skill the exam tests. Sections 5.3 to 5.9 are ADDED CONTEXT commands that help you check for phishing and pharming, plus the AI assistant command `sgpt`. Learn to read what each command does, because the exam shows a command or a menu and asks what it means.

5.1 setoolkit (Social-Engineer Toolkit) [page 6, slide 17]

Purpose: Start SET, the menu-driven social engineering toolkit from TrustedSec. Used by testers to run authorized campaigns.

Full syntax:

```
sudo setoolkit
```

Breakdown of each part:

- `sudo`: run as the administrator (root). SET needs root for some actions such as opening low ports.
- `setoolkit`: the command that starts the toolkit and shows the numbered main menu.

SET has no required command-line flags. You work by typing numbers at the `set>` prompt (verify for your version). The first run may ask you to accept terms and may offer to update through git.

Menu choice table (the "flags" of SET):

Choice	Meaning	When to use	Example path
1	Social-Engineering Attacks	Any phishing or payload test	1
2	Penetration Testing (Fast-Track)	Quick exploit helpers	2
3	Third Party Modules	Add-on modules	3
4	Update the toolkit	Before a test	4
99	Exit or go back	Leave a menu	99

Inside choice 1, the sub-menu lists the attack vectors (see section 3.20): 1 Spear-Phishing, 2 Website, 3 Infectious Media, 4 Payload and Listener, 5 Mass Mailer, 6 Arduino, 7 Wireless Access Point, 8 QRCode Generator, 9 Powershell, 10 Third Party Modules, 99 back.

Demo commands (realistic authorized scenario: lab awareness test):

```
# Start SET on the lab Kali host
sudo setoolkit
# At the menu type:  1   (Social-Engineering Attacks)
# Then type:         2   (Website Attack Vectors)
# Then pick the method the test plan allows, and a template
```

Sample output (menu, shortened):

```
Select from the menu:

  1) Social-Engineering Attacks
  2) Penetration Testing (Fast-Track)
  3) Third Party Modules
  4) Update the Social-Engineer Toolkit
  5) Update SET configuration
  6) Help, Credits, and About

 99) Exit the Social-Engineer Toolkit

set>
```

How to read it:

- "Select from the menu" tells you SET waits for a number.
- Entries 1 to 6 are the top-level choices. Attack work starts at 1.
- 99 always means exit or go back.
- `set>` is the prompt. Type the number and press Enter.

Common mistakes:

- Typing the name instead of the number.
- Running without root and getting permission errors.
- Confusing menu 2 at the top level (Fast-Track) with the "Website Attack Vectors" option 2 in the sub-menu.
- Using SET without written permission.

What the exam asks: Which number is Social-Engineering Attacks (1). Which sub-menu number creates a QR code (8) or a Spear-Phishing mail (1) or a Website attack (2). Which tool is "Python-driven" and "from TrustedSec".

5.2 shellphish.sh (ShellPhish) [page 6, slide 17]

Purpose: Start ShellPhish, a menu-driven bash script that hosts a fake login page for a chosen platform and records the visitor IP and submitted login.

Full syntax (as shown in the window title):

```
bash shellphish.sh
```

Breakdown of each part:

- `bash` : runs the script using the bash shell interpreter.
- `shellphish.sh` : the script file name shown in the screenshot title bar. [UNCLEAR on page 6: the exact file or launcher name could differ by version, verify]

ShellPhish has no required command-line flags. You choose a platform number from a menu, then the script starts a local web server and waits.

Menu choice table:

Choice (example)	Platform	When to use
01	Facebook	Lab test aimed at a Facebook-style login
02	Instagram	Lab test aimed at an Instagram-style login
14	LinkedIn	Lab test aimed at a LinkedIn-style login
other	Other listed sites	Match the platform named in the test plan

Demo commands (authorized lab scenario):

```
cd shellphish
bash shellphish.sh
# Choose option 2 for Instagram at the "Select an option" prompt
```

Sample output and how to read it:

```
[*] Initializing ... (localhost:5555)
[*] Successfully hosted at: http://localhost:5555
[*] Waiting for Login Info, Press Ctrl + C to exit
[*] Victim IP Found!
[*] Saved: sites/instagram/victim_ip.txt
[*] Login Info Found!
[*] Saved: sites/instagram/login_info.txt
[*] Waiting for Next Login Info, Press Ctrl + C to exit
```

Line-by-line meaning:

- `Initializing ... (localhost:5555)` : the local web server is starting on port 5555 [UNCLEAR on page 6: exact port, verify].
- `Successfully hosted at: http://localhost:5555` : the fake page is now reachable at this address. In a real test, a public link (often made with a tunnel tool) would be sent to the test group.
- `Waiting for Login Info, Press Ctrl + C to exit` : the tool is idle, listening for a visit.
- `Victim IP Found!` : someone opened the link; the IP address was logged.
- `Saved: sites/instagram/victim_ip.txt` : the IP was written to this file.

- `Login Info Found!` : the visitor submitted the fake form.
- `Saved: sites/instagram/login_info.txt` : the captured user name and password were written to this file.
- `Waiting for Next Login Info...` : the tool keeps running for more visitors until you press Ctrl+C.

Common mistakes:

- Forgetting that `localhost` only works on the same machine; a real test needs a reachable link, which must stay inside the approved scope.
- Leaving the captured file (`login_info.txt`) exposed on a shared machine.
- Running this against real accounts or without consent, which is illegal.

What the exam asks: What does "Victim IP Found" mean (a visitor opened the page). Where are credentials saved (a text file under `sites/<platform>/`). Which tool targets social media logins by name (ShellPhish).

5.3 Reading a QR code destination before scanning (ADDED CONTEXT)

Purpose: Check where a QR code points before trusting it, as a defense against QRLJacking and quishing (3.27).

Full syntax (using a QR-decoding command-line tool, example with `zbarimg`):

```
zbarimg qr_photo.png
```

Breakdown of each part:

- `zbarimg` : a command-line QR and barcode reader (ADDED CONTEXT, verify it is installed).
- `qr_photo.png` : the image file of the QR code to decode.

Flag table:

Flag	Meaning	When to use	Example
(none)	Decode and print the content	Basic check	`zbarimg code.png`
-q	Quiet mode, less extra output	Scripting	`zbarimg -q code.png`
-D	Display the image while scanning	Visual check	`zbarimg -D code.png`

Demo command:

```
zbarimg -q suspicious_qr.png
```

Sample output:

```
QR-Code:https://login-example.com/auth?id=99af3c
scanned 1 barcode symbols
```

How to read it: The line after `QR-Code:` is the real destination. Compare the domain (`login-example.com`) with the domain you expect. A mismatch is a warning sign, especially for a "login with QR" flow (3.27).

Common mistakes: Trusting a QR code just because it looks sharp and official. Scanning with an app that opens the link automatically instead of showing it first.

What the exam asks: How to verify a QR code before scanning it with a phone that is logged in to a sensitive account.

5.4 Checking the hosts file for pharming (ADDED CONTEXT) [relates to 3.18]

Purpose: Pharming can work through a local hosts file change. Checking this file shows whether a domain has been redirected.

Full syntax:

```
cat /etc/hosts
```

Breakdown of each part:

- `cat` : prints a file to the screen.
- `/etc/hosts` : the Linux file that maps host names to IP addresses before DNS is even asked. On Windows the file is `C:\Windows\System32\drivers\etc\hosts` .

Flag table:

Flag	Meaning	When to use	Example
(none)	Show the whole file	Quick check	`cat /etc/hosts`
-n	Number each line	Reference specific lines	`cat -n /etc/hosts`

Demo commands:

```
cat /etc/hosts
grep -i "examplebank" /etc/hosts
```

Sample output:

```
127.0.0.1       localhost
::1             localhost
203.0.113.50    examplebank.com
```

How to read it: The first two lines are normal (loopback addresses for the local machine). The third line is suspicious if `examplebank.com` is a real external bank, because a normal computer should not have a fixed local entry for it. That fixed IP may be the attacker's server (pharming).

Common mistakes: Assuming every custom hosts entry is malicious (developers add entries for testing). Confirm with the site owner or compare the IP against a public DNS lookup (5.5) before concluding it is an attack.

What the exam asks: Where pharming can hide on a victim's own machine, and which file to check (`hosts`).

5.5 nslookup (ADDED CONTEXT) [relates to 3.18]

Purpose: Compare what a name resolves to, to spot DNS cache poisoning or a pharming redirect.

Full syntax:

```
nslookup examplebank.com
```

Breakdown of each part:

- `nslookup` : the command that queries DNS.
- `examplebank.com` : the domain name to resolve.

Flag table:

Flag	Meaning	When to use	Example
(none)	Query the default DNS server	Normal check	`nslookup example.com`
-type=a	Ask only for the IPv4 address record	Focused check	`nslookup -type=a example.com`
server (second argument)	Query a specific DNS server	Compare two servers	`nslookup example.com 8.8.8.8`

Demo commands:

```
nslookup examplebank.com
nslookup examplebank.com 8.8.8.8
```

Sample output:

```
Server:     192.168.1.1
Address:    192.168.1.1#53

Name:   examplebank.com
Address: 198.51.100.20
```

How to read it: `Server` is the DNS server that answered. `Name` and `Address` show what IP the domain maps to. If your local DNS gives a different address than a trusted public DNS server (such as `8.8.8.8`), the local DNS may be poisoned.

Common mistakes: Comparing against a cached old result instead of a fresh query. Not checking which DNS server answered.

What the exam asks: How to detect DNS-based pharming (compare answers from two DNS servers).

5.6 curl -I (ADDED CONTEXT) [relates to 3.17 and 3.31]

Purpose: Check a link's real destination and basic response headers before clicking it in a browser, useful against phishing, clone phishing, and tabnabbing.

Full syntax:

```
curl -I "https://suspicious-link.example/login"
```

Breakdown of each part:

- `curl` : a command-line tool that makes web requests.
- `-I` : fetch only the response headers (HEAD-style request), not the full page.
- The quoted text: the URL to check.

Flag table:

Flag	Meaning	When to use	Example
-I	Headers only	Quick, safe check	`curl -I URL`
-L	Follow redirects	See the final destination	`curl -IL URL`
-v	Verbose, show the full exchange	Deep check	`curl -v URL`

Demo commands:

```
curl -I "https://bit.ly/3exampleShort"
curl -IL "https://bit.ly/3exampleShort"
```

Sample output:

```
HTTP/1.1 301 Moved Permanently
Location: https://totally-not-the-real-bank.example/login
Server: nginx
```

How to read it: `301 Moved Permanently` and `Location:` show that the short link redirects somewhere else. Compare that final domain with the bank's real domain. A mismatch confirms a phishing link.

Common mistakes: Opening a suspicious link directly in a normal browser session that is logged in to real accounts. Use `curl` or a sandboxed browser instead.

What the exam asks: How to check a link safely before clicking, and how to read an HTTP redirect.

5.7 sgpt (ShellGPT) for an AI-assisted social engineering defense task (ADDED CONTEXT)

Purpose: v13 AI adds AI-assisted ethical hacking. `sgpt` is a terminal AI assistant that can draft text (for example awareness material or a quick email header check) from a prompt.

Full syntax:

```
sgpt "list 5 red flags in this email header" --no-interaction
```

Breakdown of each part:

- `sgpt` : the ShellGPT command-line tool.
- The quoted text: your prompt (what you ask the AI to do).
- `--no-interaction` : run once and print the answer, without opening a chat (verify flag name for your installed version).

Flag table:

Flag	Meaning	When to use	Example
--no-interaction	One-shot answer	Scripting or quick checks	`sgpt "..." --no-interaction`
--shell	Ask for a shell command suggestion	Build a command from plain English	`sgpt --shell "list files modified today"`
--chat NAME	Keep a named chat session	Multi-step tasks	`sgpt --chat case1 "..."`

Demo commands:

```
sgpt "write a 5 question quiz that teaches staff to spot \
urgency and authority tricks"
sgpt "explain what this email header field means: \
Received-SPF: fail"
```

Sample output (illustrative):

```
1. Does the message pressure you to act within minutes?
2. Does it claim to be from a senior leader you rarely hear from?
3. Does the sender address match the display name exactly?
4. Is there a link that does not match the claimed company?
5. Does it ask for a password, OTP, or gift cards?
```

How to read it: The AI returns plain text. Treat it as a draft, not as a verified fact. Always check real headers and policies yourself.

Common mistakes: Pasting confidential company data into a public AI tool. Trusting AI output as a final decision without a human review.

What the exam asks: v13 AI questions often ask which phase an AI tool supports (recon, scripting, reporting) and what a given prompt is trying to achieve. This command sits in the "defense and training" use of AI.

5.8 Checking app permissions before install (ADDED CONTEXT) [relates to 3.25 and 3.26]

Purpose: Spot a malicious or repackaged mobile app by reviewing the permissions it asks for, using the Android Debug Bridge (adb) on a connected or emulated device.

Full syntax:

```
adb shell dumpsys package com.example.fakeapp | grep permission
```

Breakdown of each part:

- `adb` : Android Debug Bridge, a command-line tool to talk to an Android device or emulator.
- `shell` : run a command inside the device's shell.
- `dumpsys package com.example.fakeapp` : dump system information about the named app package.
- `| grep permission` : filter the output to only the lines containing the word "permission".

Flag table:

Flag or part	Meaning	When to use	Example
shell	Run inside the device shell	Any device-side check	`adb shell ...`
dumpsys package NAME	Show details for one app	Check a specific app	`dumpsys package com.app`
grep permission	Filter for permission lines	Focus the output	`| grep permission`

Demo command:

```
adb shell dumpsys package com.fake.gamestudio | grep permission
```

Sample output:

```
requested permissions:
  android.permission.READ_SMS
  android.permission.SEND_SMS
  android.permission.READ_CONTACTS
```

How to read it: A simple game asking to read and send SMS is a strong warning sign (this matches the fake security app pattern in 3.26, which can read one-time codes from SMS). Compare the permission list against what the app's stated purpose actually needs.

Common mistakes: Granting every permission a popup asks for without reading it. Assuming an app from a third-party store (3.25) is safe because it looks identical to the original.

What the exam asks: How to detect a malicious or repackaged app before installing or trusting it (review permissions and source).

5.9 Hovering and inspecting a link without clicking (ADDED CONTEXT) [relates to 3.29]

Purpose: The slide's step 3 says "hover over links to identify whether they point to the correct location." On a system without a mouse hover option (for example, when checking email source), you can read the raw link from the message source.

Full syntax (view raw email headers and body in a mail tool, example using `less` on a saved .eml file):

```
grep -A 2 "href=" suspicious_email.eml
```

Breakdown of each part:

- `grep` : search text for a pattern.
- `-A 2` : also print the 2 lines after each match, for context.
- `"href="` : the HTML attribute that holds a link's destination.
- `suspicious_email.eml` : the saved email file to inspect.

Flag table:

Flag	Meaning	When to use	Example
-A N	Show N lines after a match	See context around a link	`grep -A 2 "href=" file`
-i	Case-insensitive search	HREF vs href	`grep -i "href=" file`

Flag	Meaning	When to use	Example
-o	Print only the matching part	Extract just the link	`grep -o 'href="[^"]*"' file`

Demo command:

```
grep -o 'href="[^"]*"' suspicious_email.eml
```

Sample output:

```
href="https://docusign-completed-doc.example-xyz.net/view"
```

How to read it: Compare the domain (`example-xyz.net`) to the real DocuSign domain. A mismatch confirms the phishing lure shown in the slide 13 example (3.17).

Common mistakes: Trusting the visible link text (which can say anything) instead of the real `href` destination. Clicking the link in a live mail client to "just check", which can still trigger tracking or exploit code.

What the exam asks: How to check a link's real destination before clicking (hover, or inspect the raw HTML source).

6. Ports, Protocols, Standards and Acronyms

6.1 Protocols and channels used by this module's techniques

Item	Simple purpose	Default port or layer	Known weakness
SMTP	Sends email between mail servers	Port 25 (587 for submission)	No built-in sender proof, spoofable
HTTP	Loads web pages	Port 80	Not encrypted, easy to fake content
HTTPS	Loads web pages with encryption	Port 443	Encrypts the channel only, not the honesty of the site
DNS	Turns domain names into IP addresses	Port 53	Cache poisoning, enables pharming
SMS (SS7 and carrier networks)	Delivers text messages	Telecom layer, not IP port based	Can be spoofed, enables SMiShing
Voice or VoIP (SIP)	Carries phone calls	Port 5060 for SIP (verify)	Caller ID spoofing, enables vishing
OAuth 2.0	Lets an app act for a user without the password	Application layer (HTTPS)	Abused by consent phishing
HTML window.opener	Lets an opened page reference the page that opened it	Browser (application layer)	Abused by reverse tabnabbing

6.2 Standards, frameworks, and acronyms

Acronym	Simple purpose	Related attack or tool
SE	Social Engineering, the module topic	All techniques in this module
PII	Personally Identifiable Information	Identity theft (3.24)
OSINT	Open Source Intelligence, public info gathering	Impersonation, elicitation, Maltego
OAuth	Open standard for app permission without passwords	Consent phishing (3.19)
OTP	One-Time Password, a single-use code	Vishing, SMiShing targets this
MFA or 2FA	Multi-factor or two-factor authentication	Countermeasure (3.28)

Acronym	Simple purpose	Related attack or tool
SPF, DKIM, DMARC	Email sender authentication standards	Anti-phishing (ADDED CONTEXT)
MDM	Mobile Device Management	Mobile app countermeasure (3.25)
API	Application Programming Interface	PhishTank's data access (3.31)
SET	Social-Engineer Toolkit	Phishing tool (3.20)
QRL	Quick Response code Login	QRLJacking (3.27)
BEC	Business Email Compromise	Whaling-style fraud (3.18, ADDED CONTEXT)
LLM	Large Language Model, an AI text model	AI angle across the module
C2PA	Coalition for Content Provenance and Authenticity, a media-origin standard	Deepfake defense (3.22, ADDED CONTEXT, verify)

ADDED CONTEXT: Rare item introduced: SS7 (Signaling System No. 7) is an old telecom protocol that still routes many calls and texts worldwide. Attackers with SS7 access can intercept or redirect calls and SMS, which makes vishing and SMiShing easier at a carrier level. Mobile network operators, not end users, must secure SS7; verify current risk level.

7. Attack vs Countermeasure and Look-alike Comparisons

7.1 Attacks with their countermeasures

Attack	Best countermeasure
Impersonation	Verify identity via a second, known channel
Vishing	Never share OTPs or PINs on a call, call back on the official number
Eavesdropping	Private rooms, encrypted calls and chat (TLS)
Shoulder surfing	Privacy screens, lock the screen, avoid public entry of secrets
Dumpster diving	Shred documents, lock bins, wipe old media
Reverse social engineering	Use only the official help desk, verify unsolicited helpers
Piggybacking and tailgating	Mantraps, one-badge-one-person policy, guards
Diversion theft	Verify delivery changes through the original sender
Honey trap and catfishing	Limit shared work details online, verify new contacts
Baiting	Disable autorun, control USB use, scan unknown media
Quid pro quo	Staff trained to know the real IT support process
Elicitation	Teach what is confidential, polite deflection
Phishing (all types)	Spam filters, hover over links, confirm sender, MFA
Pharming	DNSSEC, patch DNS servers, check TLS certificates
Spimming	Block unknown IM senders, filter links
Clone phishing	Verify "resent" mail with the real sender
Tabnabbing or reverse tabnabbing	rel="noopener noreferrer", check tab before typing
Consent phishing	Restrict app consent, review and revoke app permissions
Search engine phishing	Use bookmarks, avoid unknown download sites
Fake security apps or malicious apps	Install only from official stores, review permissions
SMiShing	Never call numbers from unsolicited texts
QRLJacking	Check device and location prompts, review linked devices
Deepfake or voice cloning	Callback verification, code words, dual approval
Identity theft	Shred, monitor statements, limit public identifiers

7.2 Look-alike pairs

X vs Y	The difference in one line	How to tell them apart
Piggybacking vs Tailgating	Insider knowingly lets you in vs you sneak in behind	"Please hold the door" = piggyback; fake badge, no interaction = tailgate
Eavesdropping vs Shoulder surfing	Hearing vs seeing	Ears for eavesdropping, eyes for shoulder surfing
Baiting vs Quid pro quo	An object is offered vs a service is offered	USB drive = bait; "I'll fix your PC" = quid pro quo
Spear phishing vs Whaling	A specific person or small group vs a top executive	Job title of the victim decides
Phishing vs Pharming	Needs a click on a bait vs redirects even correct typing	Pharming changes DNS or hosts, no bait needed
Vishing vs SMiShing vs Phishing	Voice call vs SMS text vs email or web page	The channel used for the first contact
Angler phishing vs Catfishing	Fake company support account vs fake personal identity	Target is a complaining customer vs a trusting individual
Honey trap vs Catfishing	Targets a company insider for secrets vs targets a person for money or harm	Goal is corporate data vs personal exploitation
Honey trap vs Honeypot	A fake romantic person vs a decoy computer system	Honeypot is a defensive IT system (Module 12), not a person
Tabnabbing vs Reverse tabnabbing	An idle tab is changed vs a newly opened tab changes the original	Which tab changes, the one you left or the one you came from
Deepfake vs Voice cloning	Fake video or image vs fake audio only	Check whether video or only sound is faked
Impersonation vs Identity theft	One conversation acting as someone vs using stolen data for fraud	Scope and duration of the deception

8. Exam Cheat Sheet

8.1 Keyword to answer

Keyword in the question	Likely answer
"most common human-based technique"	Impersonation
"weakest link"	Human behavior or the human element
"forgot my ID badge"	Piggybacking
"fake ID badge, followed closely"	Tailgating
"attacker becomes the authority, victim calls"	Reverse social engineering
"USB flash drive left in a location"	Baiting
"random calls, claims to be tech support"	Quid pro quo
"attractive person, fake online relationship"	Honey trap
"normal and disarming conversation"	Elicitation
"targeted at specific individuals or small group"	Spear phishing
"CEO, CFO, high-profile executive"	Whaling
"phishing without a lure", "DNS cache poisoning"	Pharming
"spam over instant messaging"	Spimming
"nearly identical copy of a legitimate email"	Clone phishing
"changes content while you are on another tab"	Tabnabbing
"new tab changes the original tab"	Reverse tabnabbing
"abuses OAuth"	Consent phishing
"manipulates search engine results"	Search engine phishing
"fake helpdesk account on social media"	Angler phishing
"fake identity for cyberbullying or money"	Catfishing
"SMS lures into instant action"	SMiShing
"exploits login with QR code"	QRLJacking
"duplicate of a static or dynamic QR code"	QR TIGER
"Python-driven toolkit, TrustedSec"	SET
"phish Instagram, Facebook, Twitter, LinkedIn credentials"	ShellPhish
"neighborhood watch" phishing defense	Netcraft
"collaborative clearing house", "open API"	PhishTank
"test employees' susceptibility"	OhPhish
"sign a statement" after training	Social engineering countermeasure

Keyword in the question	Likely answer
"no specific software or hardware" fully defends	Social engineering concept

8.2 Must-memorize lists

- Eight weak behaviors: Authority, Intimidation, Consensus, Scarcity, Urgency, Familiarity, Trust, Greed.
- Three types of SE: Human-based, Computer-based, Mobile-based.
- 14 human-based techniques: Impersonation, Vishing, Eavesdropping, Shoulder Surfing, Dumpster Diving, Reverse SE, Piggybacking, Tailgating, Diversion Theft, Honey Trap, Baiting, Bait and Switching, Quid Pro Quo, Elicitation.
- 7 computer-based techniques: Pop-up Window, Phishing, Instant Chat Messenger, Spam Mail, Scareware, Deepfake Videos, Voice Cloning.
- 5 mobile-based techniques: Fake Security Apps, Publishing Malicious Apps, SMiShing, Repackaging Legitimate Apps, QRLJacking.
- 9 phishing variants named in the notes: Spear Phishing, Whaling, Pharming, Spimming, Clone Phishing, E-wallet Phishing, Tabnabbing or Reverse Tabnabbing, Consent Phishing, Search Engine Phishing.
- 10 general countermeasures (slide 30): Train, Access privileges, Incidence response time, Resources to authorized users only, Scrutinize information, Background check and termination, Anti-virus or anti-phishing, Two-factor authentication, Change management, Regular updates.
- 8 anti-phishing steps (slide 31): Educate, Spam filters, Hover, Check mistakes, Confirm sender, Ensure HTTPS, Reverse image search, Report fake accounts.
- 10 identity theft countermeasures (slide 32): Shred documents, Avoid marketers' hit lists, Review statements, Never give info by phone, Empty mailbox quickly, Verify requests, Protect info from publicity, Do not share account numbers, Monitor online banking, No personal identifiers on social media.

8.3 Numbers and defaults

Item	Number or default
SET main menu exit code	99
ShellPhish example local port in the notes	5555 (example, verify for your version)
HTTP default port	80
HTTPS default port	443
DNS default port	53
SMTP default port	25 (587 for submission)

8.4 Rules for picking the BEST option

1. If one option is "training and policy" and another is "a single technical tool", pick training and policy, because social engineering has no complete technical fix.
2. If a scenario names a specific tool behavior (TrustedSec, Python, menu-based) pick SET; if it names social media credential capture, pick ShellPhish.
3. If the question gives a channel (voice, SMS, email, in person), match the SE type to that channel first, then narrow to the specific technique.
4. If a password was never exposed but access continues after a password reset, think OAuth or consent phishing, and the fix is to revoke the app's access token, not just change the password.
5. If the scenario mentions seeing or hearing someone that looks or sounds real, remember that AI-made deepfakes can defeat visual or voice trust, so the best next step is out-of-band verification, not "I recognized them."
6. If two options both look like policy fixes, pick the one that matches the exact slide wording (for example "sign a statement", "gap analysis") since CEH exam answers often map to literal courseware phrases.

9. Practice Questions

These are original practice questions written for this guide. They are not reproductions of any real exam. The answer and explanation for each question are placed directly below it, as requested.

Q1. A caller tells the help desk, "This is Kevin, CFO's secretary, I'm working on an urgent project and lost my password, can you help me out?" Which technique is this?

A. Reverse social engineering B. Impersonation C. Quid pro quo D. Elicitation

Answer: B. The caller pretends to be an authorized person (a VIP's secretary) to get a password. This matches the slide's "Posing as an important user" example of impersonation. - A is wrong because the victim did not come to the attacker asking for help; the attacker called and asked for something. - C is wrong because the attacker is not offering a service in exchange for data. - D is wrong because this is a direct request, not a slow, disarming conversation.

Q2. An employee lets a visitor through a secure door after the visitor says, "I forgot my ID badge at home, please help me." What is this?

A. Tailgating B. Piggybacking C. Diversion theft D. Baiting

Answer: B. The notes define piggybacking with exactly this example: an authorized person allows an unauthorized person through. - A is wrong because tailgating uses a fake ID badge and following closely, without the insider's clear awareness. - C is wrong because no delivery is involved. - D is wrong because no item or lure is left behind; this is a direct verbal request.

Q3. A USB drive labeled "Payroll_2026_Confidential" is found in the company car park. An employee plugs it into a work laptop. What technique was used against the employee?

A. Quid pro quo B. Baiting C. Diversion theft D. Honey trap

Answer: B. The notes define baiting as leaving a device such as a USB drive where people can easily find it. - A is wrong because no service was offered in a conversation. - C is wrong because no delivery was redirected. - D is wrong because no relationship or romantic lure was used.

Q4. Which phishing variant specifically targets CEOs, CFOs, and other senior leaders?

A. Spear phishing B. Whaling C. Pharming D. Spimming

Answer: B. The notes state whaling targets high-profile executives like CEOs and CFOs. - A is wrong because spear phishing targets any specific individual or small group, not necessarily top leadership. - C is wrong because pharming is about DNS or hosts-file redirection, not a target's rank. - D is wrong because spimming is spam delivered over instant messaging.

Q5. A user types her bank's correct web address, but lands on a fake copy of the site because her computer's hosts file was changed. What attack is this?

A. Phishing B. Pharming C. Clone phishing D. Tabnabbing

Answer: B. The notes describe pharming as "phishing without a lure," performed using DNS cache poisoning or host file modification, exactly matching this scenario. - A is wrong because phishing needs the victim to click a bait link; here the victim typed the correct address. - C is wrong because clone phishing copies a previously received message, which is not described here. - D is wrong because tabnabbing changes a tab's content while the user is away from it, not the DNS resolution.

Q6. A bot harvests instant messaging IDs and floods those accounts with spam links. What is this called?

A. SMiShing B. Vishing C. Spimming D. Scareware

Answer: C. The notes define spimming as a variant of spam that exploits instant messaging platforms using bots to harvest IM IDs. - A is wrong because SMiShing uses SMS text messages, not instant messaging bots. - B is wrong because vishing is a voice phone call. - D is wrong because scareware uses fear of infection to push a download or purchase, not IM spam.

Q7. An attacker copies a previously sent, legitimate invoice email and changes only the payment link, then resends it. What is this?

A. Clone phishing B. Search engine phishing C. Consent phishing D. E-wallet phishing

Answer: A. The notes define clone phishing as a nearly identical copy of a legitimate communication where the link or attachment is modified. - B is wrong because that involves manipulated search results, not a copied email. - C is wrong because that abuses OAuth permission screens, not an email copy. - D is wrong because that targets electronic wallet users specifically, not a general invoice.

Q8. A victim opens a link that appears to be a legitimate website. After a while, the content of the original tab (the one that had the link) changes to a fake login page. What is this?

A. Tabnabbing B. Reverse tabnabbing C. QRLJacking D. Angler phishing

Answer: B. The notes describe reverse tabnabbing as: a seemingly legitimate website deceives users into opening a malicious link, which then alters the content of the original tab to a phishing site. - A is wrong because plain tabnabbing changes the content of the tab the victim left idle, not the tab that opened a new link. - C is wrong because QRLJacking involves a QR code login session, not browser tabs. - D is wrong because angler phishing uses a fake social media support account.

Q9. A fake application requests permission to act on behalf of a user's email account using the account provider's real login and consent screen. The user clicks "Allow." No password was stolen. What is this attack, and what is the best remediation?

A. Phishing; reset the user's password B. Consent phishing; revoke the app's access token C. Pharming; flush the DNS cache D. Clone phishing; report the sender

Answer: B. The notes describe consent phishing as exploiting OAuth with a fake application that the victim allows through the real provider's consent screen. Because no password was taken, resetting the password does not remove access. The app's granted token must be revoked. - A is wrong because a password reset does not undo an OAuth grant. - C is wrong because no DNS manipulation is described. - D is wrong because no previously received email was copied.

Q10. Which tool, according to the module, is an open-source, Python-driven toolkit from TrustedSec aimed at penetration testing around social engineering?

A. ShellPhish B. SET (Social-Engineer Toolkit) C. Gophish D. QR TIGER

Answer: B. The notes state this description word for word about SET. - A is wrong because ShellPhish is a bash script that targets specific social media login pages. - C is wrong because Gophish is a phishing simulation framework, not described as Python-driven or from TrustedSec in the notes. - D is wrong because QR TIGER is a QR code generator tool.

Q11. In SET's main menu, which numbered option exits the toolkit?

A. 0 B. 1 C. 99 D. Exit

Answer: C. The screenshot shows option 99 labeled "Exit the Social-Engineer Toolkit." - A is wrong because 0 is not shown as a menu option. - B is wrong because 1 starts Social-Engineering Attacks. - D is wrong because the menu uses numbers, not the word "Exit", to make the selection.

Q12. A tester runs `bash shellphish.sh` and selects the Instagram option. The terminal then prints "Login Info Found!" and "Saved: sites/instagram/login_info.txt". What just happened?

A. The tool scanned the Instagram server for open ports B. A visitor submitted credentials into the fake login page, and they were saved to a file C. The tool cloned a QR code for Instagram D. The tool sent a mass email to Instagram users

Answer: B. This is a direct read of the sample output: the fake page captured credentials and wrote them to the named file. - A is wrong because ShellPhish hosts a fake page; it does not scan the real Instagram servers. - C is wrong because QR code cloning is the QRLJacking and QR TIGER use case, not ShellPhish. - D is wrong because no mass email is shown in this tool's workflow.

Q13. Which command below would help a defender check whether a shortened URL redirects to an unexpected domain, without opening it in a logged-in browser?

A. `nslookup examplebank.com` B. `curl -IL "https://bit.ly/3exampleShort"` C. `cat /etc/hosts` D. `adb shell dumpsys package com.app`

Answer: B. `curl -IL` fetches headers and follows redirects, revealing the `Location` header with the final destination domain, without rendering the page in a browser. - A is wrong because `nslookup` resolves a domain name to an IP, it does not follow a URL's redirect chain. - C is wrong because that inspects the local hosts file for pharming entries, not a shortened URL. - D is wrong because that inspects Android app permissions, unrelated to a web link.

Q14. A security team finds that `android.permission.SEND_SMS` and `android.permission.READ_SMS` are requested by a simple offline puzzle game downloaded from a third-party app store. What should this raise suspicion of?

A. QRLJacking B. A repackaged or malicious app designed to intercept one-time codes C. Spimming D. Search engine phishing

Answer: B. An offline puzzle game has no legitimate reason to read or send SMS messages; this pattern matches malware that intercepts one-time passcodes, consistent with the fake security app and repackaging techniques in the notes. - A is wrong because QRLJacking involves QR-based login sessions, not SMS permissions. - C is wrong because spimming is instant-messaging spam, unrelated to Android permissions. - D is wrong because search engine phishing concerns manipulated search rankings.

Q15. During a live video call, "colleagues" and the "CFO" ask a clerk to urgently wire funds. Later, it is found that all faces on the call were AI-generated. What is the single best preventive control that would have stopped the loss?

A. A stronger email spam filter B. A mandatory callback or dual-approval process using a known contact outside the video call C. A longer company password policy D. An anti-phishing browser toolbar

Answer: B. Deepfakes defeat visual and audio trust, so the exam's "best next step" logic favors a process control (verify through an independent, known channel, and require a second approver) over tools that address a different type of attack. - A is wrong because this attack used a video call, not email. - C is wrong because no password was involved. - D is wrong because no phishing webpage or link was part of this attack.

Q16. A victim scans a QR code shown on a chat application's "login with QR code" screen, not realizing the code was cloned and relayed by an attacker. The attacker is then logged in as the victim. What is this attack, and which tool on the slide can create a duplicate of such a QR code?

A. SMiShing; ShellPhish B. QRLJacking; QR TIGER C. Tabnabbing; Netcraft D. Consent phishing; SET

Answer: B. This matches the notes' definition and diagram for QRLJacking exactly, and QR TIGER is named as the tool that clones static or dynamic QR codes. - A is wrong because SMiShing is an SMS-based lure, and ShellPhish targets normal login pages, not QR logins. - C

is wrong because tabnabbing concerns browser tabs, and Netcraft is a defensive anti-phishing tool, not an attack tool. - D is wrong because consent phishing abuses OAuth consent screens, and SET is not shown creating QR clones in the notes (its QR vector generates a URL-pointing code, not a session clone).

Q17. Which free, community-driven service provides an open API so that developers can check whether a URL has been verified as a phishing site?

A. Netcraft B. OhPhish C. PhishTank D. Gophish

Answer: C. The notes describe PhishTank exactly this way: a collaborative clearing house with an open API for integrating anti-phishing data. - A is wrong because Netcraft is described as a community-powered browser extension that blocks suspected pages, without emphasis on an open API in the notes. - B is wrong because OhPhish is an internal employee-testing portal, not a public URL-verification API. - D is wrong because Gophish is a phishing simulation framework for running campaigns, not a URL reputation API.

Q18. An organization wants to measure and train employees against phishing by launching simulated "Credential Harvesting" and "Vishing" campaigns and tracking who clicked or was fooled. Which tool from the notes matches this purpose?

A. ShellPhish B. SET C. OhPhish D. Modlishka

Answer: C. OhPhish's dashboard specifically lists campaign modes such as Credential Harvesting, Vishing, and Smishing, and is described as a platform to test employees' susceptibility. - A is wrong because ShellPhish is an attacker-style tool for capturing credentials, not a defensive awareness platform. - B is wrong because SET is a general-purpose offensive toolkit, not an employee-testing dashboard. - D is wrong because Modlishka is a reverse-proxy phishing relay tool, not mentioned as an awareness platform in the notes.

Q19. A company receives chain letter emails that promise a cash reward if the recipient forwards the message to twenty people. According to the notes, what is this technique mainly used by attackers to accomplish?

A. Immediate credential theft B. Harvesting and verifying working email addresses for later spam or phishing use C. Installing ransomware instantly D. DNS cache poisoning

Answer: B. The pattern of promising rewards for forwarding is a classic address-harvesting and propagation technique, consistent with the notes' description of chain letters offering free gifts on condition of forwarding. - A is wrong because the chain letter itself does not directly ask for credentials. - C is wrong because no installation step is part of this technique. - D is wrong because DNS manipulation is unrelated to email forwarding chains.

Q20. A customer complains about a bank on social media. Within minutes, an account named "BankHelp_Support" replies with a link claiming to resolve the issue. The link leads to a fake login page. What is this specific technique called?

A. Catfishing B. Angler phishing C. Honey trap D. Elicitation

Answer: B. The notes define angler phishing as attackers creating a fake social media account impersonating an organization's helpdesk and connecting with disgruntled customers via fake service links. - A is wrong because catfishing builds a fake personal identity for a relationship, not a fake company support handle. - C is wrong because a honey trap uses a fake romantic relationship to target a company insider. - D is wrong because elicitation is a conversational technique, not a social media support impersonation.

Q21. Which of the following is NOT one of the eight behaviors the notes list as vulnerable to social engineering attacks?

A. Scarcity B. Curiosity C. Urgency D. Greed

Answer: B. The eight listed behaviors are Authority, Intimidation, Consensus, Scarcity, Urgency, Familiarity, Trust, and Greed. Curiosity is not on this list, though it is commonly associated with baiting in general security literature. - A, C, and D are each explicitly listed on the slide, making them incorrect choices for "NOT listed."

Q22. Which countermeasure category would "escorting visitors" and "employing security personnel" fall under, according to the notes?

A. Password policies B. Physical security policies C. Defense strategy D. Identity theft countermeasures

Answer: B. The notes list escorting visitors and employing security personnel directly under Physical Security Policies. - A is wrong because password policies cover password changes, complexity, and secrecy. - C is wrong because defense strategy covers campaigns, gap analysis, and remediation. - D is wrong because identity theft countermeasures focus on protecting personal data such as statements and mail.

Q23. A penetration tester wants to find the final landing page of a suspicious shortened link without risking her logged-in browser session. Which single flag combination on `curl` both fetches headers only and follows any redirects to reveal the final destination?

A. `-v` B. `-IL` C. `-o` D. `-A`

Answer: B. `-I` requests headers only, and `-L` follows redirects, together revealing the final destination safely, as shown in the command sheet. - A is wrong because `-v` is verbose mode, which shows more detail but does not by itself follow redirects. - C is wrong because `-o` saves output to a file, unrelated to redirect-following. - D is wrong because `-A` sets a custom user agent string, not related to following redirects.

Q24. Which statement best distinguishes a honey trap from a honeypot?

A. A honey trap is a decoy server; a honeypot is a fake romantic relationship B. A honey trap targets a person using a fake relationship; a honeypot is a decoy IT system used to attract

and study attackers C. They are the same term used interchangeably in all contexts D. A honey trap is used only in mobile-based attacks

Answer: B. This matches the notes' trap warning distinguishing a honey trap (3.12) as a human-targeting relationship scam, from a honeypot (covered in Module 12) which is a defensive decoy system. - A reverses the correct definitions. - C is wrong because the exam specifically tests the difference between these look-alike terms. - D is wrong because a honey trap is a human-based technique, not mobile-based.

Q25. An AI chatbot sold on criminal forums is reportedly used to write convincing, grammar-perfect phishing emails and malicious code at scale. This development most directly weakens which traditional phishing-detection tip?

A. Confirming the sender through a second channel B. Checking emails for generic salutations, spelling, and grammar mistakes C. Hovering over links to see the real destination D. Enabling spam filters

Answer: B. AI-written phishing text tends to have correct grammar and personalized salutations, removing the classic warning signs that this tip relies on. The notes' AI angle sections repeatedly flag this. - A, C, and D remain effective because they do not depend on spotting writing mistakes; they check identity, destination, and automated filtering instead.

Q26. A company's help desk receives dozens of random calls over a week, each caller claiming to be from "IT Support" and offering to fix a problem in exchange for the user's login details. Which technique is being used, and what is the key giveaway?

A. Reverse social engineering; the victim initiated contact B. Quid pro quo; numerous random calls offering a service for data C. Baiting; an item was left for the victim D. Diversion theft; a delivery was redirected

Answer: B. The notes define quid pro quo as attackers calling numerous random numbers claiming to be technical support and offering their service in exchange for confidential data or credentials. - A is wrong because here the attacker initiates the calls, not the victim. - C is wrong because no physical item or lure was left. - D is wrong because no delivery or consignment is involved.

Q27. Which of these best explains why "no specific software or hardware" can fully defend against social engineering, according to the module's concepts section?

A. Because social engineering exploits human behavior and decision-making, which technology cannot fully control B. Because social engineering tools are too expensive to detect C. Because firewalls are outdated technology D. Because social engineering only happens over unencrypted channels

Answer: A. The notes state that security policies are only as strong as their weakest link, human behavior, and that there is no complete technical fix. - B, C, and D are not reasons given in the notes and are factually weak explanations.

Q28. A victim receives a message that looks exactly like a bank text she has seen before, asking her to call a number due to "suspicious account activity." She calls, and a recording asks for her card number. Which combination of techniques best describes this scenario end to end?

A. SMiShing leading into a vishing-style voice prompt B. Spear phishing leading into pharming C. Angler phishing leading into a honey trap D. QRLJacking leading into tabnabbing

Answer: A. The lure arrives by SMS (SMiShing), and the final data-collection step uses a recorded voice call (a vishing-style element), matching the slide's own XIM bank example structure. - B is wrong because no email and no DNS manipulation are involved. - C is wrong because no social media support account or romantic relationship is involved. - D is wrong because no QR code or browser tab manipulation is involved.

Q29. In the module's countermeasures, what should happen immediately after employees receive security policy training?

A. Nothing further is required B. Employees should sign a statement acknowledging they understand the policies C. Employees should be given administrator access D. The training should be deleted to save storage

Answer: B. The notes state this directly: after training, employees should sign a statement acknowledging that they understand the policies. - A, C, and D contradict the stated best practice and introduce unnecessary risk.

Q30. Why does changing a user's password NOT fully remediate a consent phishing incident?

A. Because the attacker used malware, not OAuth B. Because the attacker's access was granted through an OAuth token, which remains valid independent of the password C. Because passwords cannot be changed after a breach D. Because consent phishing only affects mobile devices

Answer: B. Consent phishing grants an app an access token through the real provider's consent screen; the password was never needed or exposed, so changing it does not revoke the token. The access must be explicitly revoked. - A is wrong because this scenario is specifically OAuth-based, not malware-based. - C is incorrect as a general statement about passwords. - D is wrong because consent phishing is not limited to mobile devices.

10. Flashcards

Q: What is social engineering? | A: The art of convincing people to reveal confidential information.

Q: Name the eight weak behaviors social engineers exploit. | A: Authority, Intimidation, Consensus, Scarcity, Urgency, Familiarity, Trust, Greed.

Q: What are the three types of social engineering? | A: Human-based, Computer-based, Mobile-based.

Q: What is the most common human-based social engineering technique? | A: Impersonation.

Q: Difference between piggybacking and tailgating? | A: Piggybacking has the insider's awareness and consent; tailgating uses a fake badge and sneaking in closely behind someone.

Q: What is reverse social engineering? | A: The attacker poses as an authority, and the victim comes to the attacker for help.

Q: What is diversion theft? | A: Tricking a delivery person into sending a consignment to the wrong location.

Q: What is a honey trap? | A: A fake online relationship used to extract confidential company information from an insider.

Q: What is baiting? | A: Offering something alluring, such as a found USB drive, to trick a victim into acting.

Q: What is quid pro quo? | A: Calling random numbers claiming to be tech support, offering a service for data.

Q: What is elicitation? | A: Extracting information through normal, disarming conversation.

Q: What is vishing? | A: Phishing carried out over a voice phone call.

Q: What is phishing? | A: Sending an illegitimate email claiming to be from a legitimate site to acquire personal or account data.

Q: What is spear phishing? | A: A targeted phishing attack aimed at a specific person or small group.

Q: What is whaling? | A: Phishing aimed at high-profile executives like CEOs and CFOs.

Q: What is pharming? | A: Redirecting web traffic using DNS cache poisoning or host file modification, also called phishing without a lure.

Q: What is spimming? | A: Spam sent over instant messaging platforms, often using bots to harvest IM IDs.

Q: What is clone phishing? | A: A near-identical copy of a legitimate message with the link or attachment replaced.

Q: What is e-wallet phishing? | A: Phishing that targets electronic wallet users by posing as the wallet provider.

Q: What is tabnabbing? | A: A malicious page changes its content to look like a login page while the victim is on another tab.

Q: What is reverse tabnabbing? | A: A newly opened tab alters the content of the original tab into a phishing page.

Q: What is consent phishing? | A: Abusing OAuth by tricking a victim into granting a fake app permission through a real consent screen.

Q: What is search engine phishing? | A: Manipulating search rankings to lead victims to fraudulent sites.

Q: What is the Social-Engineer Toolkit (SET)? | A: An open-source, Python-driven penetration testing toolkit from TrustedSec for social engineering attacks.

Q: What does ShellPhish do? | A: Hosts fake login pages for platforms like Instagram and Facebook to capture credentials.

Q: Name three other phishing tools listed besides SET and ShellPhish. | A: Any three of: Dark-Phish, BLACKEYE, SocialFish, Modlishka, Trape, Gophish, King Phisher.

Q: What is a pop-up window attack? | A: A sudden window asking for login or user information while browsing.

Q: What is the difference between a hoax letter and a chain letter? | A: A hoax letter gives a false virus warning; a chain letter promises a reward for forwarding the mail.

Q: What is scareware? | A: Malware that uses fake infection alerts to trick users into visiting malicious sites or buying fake software.

Q: What is angler phishing? | A: A fake social media account posing as an organization's helpdesk that targets disgruntled customers with fake service links.

Q: What is catfishing? | A: Using a fake social media identity, often built from a real person's stolen data, to deceive others for money or harm.

Q: What is identity theft? | A: A crime where an imposter steals personally identifiable information to commit fraud or other crimes.

Q: Name two indications of identity theft. | A: Any two of: unfamiliar card charges, missing statements, fraud department calls, unknown medical charges, missing utility bills.

Q: What is the difference between publishing malicious apps and repackaging legitimate apps? | A: Publishing creates a brand-new fake app; repackaging takes a real app and adds malware before redistributing it.

Q: What is SMiShing? | A: Phishing carried out through SMS text messages to lure users into urgent action.

Q: What is QRLJacking? | A: A social engineering attack that clones a QR code login session to hijack a victim's account.

Q: What does QR TIGER do? | A: Generates and clones static or dynamic QR codes.

Q: What does Netcraft provide? | A: A community-powered anti-phishing browser extension that blocks suspected phishing pages.

Q: What does PhishTank provide? | A: A collaborative phishing URL database with an open API.

Q: What is OhPhish used for? | A: Testing employees' susceptibility to social engineering through simulated phishing campaigns.

Q: What should happen after security awareness training? | A: Employees should sign a statement acknowledging they understand the policies.

11. Glossary

Angler phishing: A fake social media support account used to lure disgruntled customers into clicking malicious links.

Authority (trigger): A psychological pressure where the victim obeys because the attacker appears to be a boss or official.

Baiting: Offering an alluring item, such as an infected USB drive, to tempt a victim into an unsafe action.

BEC (Business Email Compromise): Fraud where an attacker impersonates an executive or partner by email to trigger a payment or data transfer (added context).

Catfishing: Building a fake social media identity, often using a real person's stolen data, to deceive others for money, harassment, or fraud.

Chain letter: An email promising a reward if the recipient forwards it to a set number of people.

Clone phishing: A near-identical copy of a previously received legitimate message, with the link or attachment replaced by a malicious one.

Consent phishing: An attack that abuses the OAuth protocol by tricking a victim into granting a fake application access through a real consent screen.

CVE, CVSS, NVD, CWE: Not part of this module; see Module 05 glossary.

Deepfake: AI-generated fake video, image, or audio that shows a real person doing or saying something they never did.

Diversion theft: Tricking a delivery or courier worker into sending a consignment to a location other than the intended one.

Dumpster diving: Searching an organization's trash, printer bins, or desks for useful information such as bills or sticky notes.

Eavesdropping: Unauthorized listening to or interception of conversations, audio, video, or written communication.

Elicitation: Extracting information from a victim through normal, friendly, disarming conversation.

E-wallet phishing: Phishing that targets electronic wallet users by posing as the wallet provider.

Familiarity (trigger): A psychological pressure where the victim trusts the attacker because the attacker seems like someone known or friendly.

Fake security application: A malicious mobile app disguised as a security tool that steals credentials once installed.

Gap analysis: Comparing current employee behavior against the desired policy outcome to find weaknesses.

Greed (trigger): A psychological pressure where the victim acts in hope of a prize, money, or reward.

Hoax letter: An email that issues a false warning about a virus, Trojan, or worm.

Honey trap: A fake online romantic relationship used to extract confidential information from a company insider.

Honeypot: A decoy IT system used by defenders to attract and study attackers (Module 12 term, included here only for contrast with honey trap).

Identity theft: A crime in which an imposter steals personally identifiable information to commit fraud or other crimes.

Impersonation: Pretending to be a legitimate or authorized person to trick a target into revealing information.

Instant chat messenger (attack): Gathering personal information such as birth dates by chatting with a selected victim online.

Intimidation (trigger): A psychological pressure using fear of a bad consequence to force compliance.

Mantrap (added context): A double-door physical security control that allows only one verified person through at a time.

MFA or 2FA: Multi-factor or two-factor authentication, an added login step beyond a password.

OAuth: An open standard that lets one application act on a user's behalf without seeing the user's password.

OhPhish: A web-based portal that tests employees' susceptibility to social engineering through simulated campaigns.

OSINT: Open Source Intelligence, information gathered from publicly available sources.

PhishTank: A collaborative, community-verified database of phishing URLs with an open API.

Pharming: Redirecting web traffic to a fraudulent site via DNS cache poisoning or host file modification, known as phishing without a lure.

Phishing: Sending an illegitimate message claiming to be from a legitimate source to acquire personal or account information.

Piggybacking: An authorized person knowingly or unknowingly allows an unauthorized person to pass through a secure door.

PII: Personally Identifiable Information, data that can identify a specific person.

Pop-up window attack: A sudden browser window that asks for login or personal information.

Publishing malicious apps: Creating and uploading fake apps with attractive, deceptive names to app stores.

Quid pro quo: Offering a service, often fake technical support, in exchange for confidential data or credentials.

QR TIGER: A QR code generator and cloning tool used to duplicate static or dynamic QR codes.

QRLJacking: An attack that clones a QR code login session to hijack a victim's account.

Repackaging legitimate apps: Taking a real app, adding malware, and redistributing it through a third-party store.

Reverse social engineering: The attacker presents as an authority, and the victim initiates contact seeking help.

Reverse tabnabbing: A newly opened malicious tab alters the content of the tab that opened it into a phishing page.

Scarcity (trigger): A psychological pressure where the victim acts quickly because something appears limited in supply.

Scareware: Malware that uses fake infection alerts to push victims toward malicious downloads or purchases.

Search engine phishing: Manipulating search engine rankings to lead victims to fraudulent websites.

SET (Social-Engineer Toolkit): An open-source, Python-driven penetration testing toolkit from TrustedSec.

ShellPhish: A bash-based phishing tool that hosts fake login pages for popular social platforms.

Shoulder surfing: Directly observing a victim's screen, keypad, or documents, sometimes from a distance using binoculars.

SMiShing: Phishing conducted through SMS text messages.

Spear phishing: A targeted phishing attack aimed at a specific person or small group.

Spimming: Spam distributed over instant messaging platforms, often using bots to harvest IM IDs.

Tabnabbing: A malicious page changes its content into a fake login page while the victim is away on another tab.

Tailgating: An attacker, using a fake ID badge, follows an authorized person closely through a secured door.

Trust (trigger): A psychological pressure built over time through a seemingly genuine relationship.

Urgency (trigger): A psychological pressure demanding immediate action to prevent careful thought.

Vishing: Phishing conducted through a voice phone call.

Voice cloning: An AI technique that reproduces a person's voice from a short audio sample.

Whaling: Phishing aimed specifically at high-profile executives such as CEOs and CFOs.

12. Coverage Report

12.1 Map of your pages to guide sections

Page	Printed slide	Guide section
1	2	3.1
1	4	3.2
2	5	3.3
2	7	3.4
3	9	3.5, 3.6, 3.7
3	10	3.8, 3.9, 3.10, 3.11
4	11	3.12, 3.13, 3.14, 3.15
4	13	3.17
5	15	3.18
5	16	3.19
6	17	3.20
6	19	3.21
7	22	3.23
7	23	3.24
8	25	3.25
8	26	3.26
9	27	3.27
9	29	3.28
10	30	3.28
10	31	3.29
11	32	3.30
11	34	3.31
12	35	3.32
12	36	3.33

12.2 Items marked [UNCLEAR]

- Page 4, slide 13: the web address shown on the fake Microsoft-style login page is too small to read with confidence.

- Page 6, slide 17: the exact local port number in the ShellPhish output, the exact menu numbering and full platform list, and the captured account or password values (hidden in the screenshot).
- Page 7, slide 22: the MySpace and Google+ icons are small and these are older, largely inactive networks; confirm current relevance before study.
- Page 8, slide 26: the exact order of some numbered steps in the "Fake Security Applications" diagram, and the phone number shown in the SMiShing example.
- Page 9, slide 27: the first step number in the QRLJacking diagram appears cut off.
- Page 11, slide 34: the small button labels on the Netcraft warning page.
- Page 12, slide 35: some column headers in the OhPhish "Live Phishing Campaigns" table.

12.3 Items to double check (verify)

- Exact current tool names and status for WormGPT and FraudGPT, since malicious AI services change quickly and are frequently taken down or rebranded.
- Current NIST password guidance versus the slide's "periodic password changes" recommendation; study the slide version for the exam, but know the newer guidance exists.
- Exact ShellPhish script name, menu structure, and default port, since community phishing tools are updated often.
- Whether OhPhish and QR TIGER are EC-Council-affiliated products or independent commercial tools.
- The SS7 content in section 6.2, added as background on telecom-level vishing and SMiShing risk.
- The C2PA content standard reference in section 3.22, added as a defensive concept for deepfake provenance.

12.4 Coverage confirmation

Every line in the inventory file (work file, not delivered) has been placed into a numbered topic section: concepts and behaviors (3.2, 3.3), all 14 human-based techniques (3.4 to 3.16), all 9 named phishing variants plus general phishing (3.17 to 3.19), both named phishing tools and all 7 "other tools" (3.20), all 6 other computer-based techniques (3.21), the AI-based impersonation topics named in the module summary (3.22), impersonation on social sites and identity theft (3.23, 3.24), all 5 mobile-based techniques (3.25 to 3.27), all countermeasure slides (3.28 to 3.30), both anti-phishing and audit tools (3.31, 3.32), and the module summary (3.33). Printed slides not present in the screenshots (3, 6, 8, 12, 14, 18, 20, 21, 24, 28, 33) are addressed as ADDED CONTEXT in section 3.34 and inline notes, so no topic area is left blank.